

INSTITUTO TECNOLÓGICO DE AERONÁUTICA



Milton de Jesus Melo

*Análise da Difusão de Malware em Honeypots
de Baixa Interatividade
Nepenthes x Dionaea*

Trabalho de Conclusão de Curso
2011

Segurança da Informação

MILTON DE JESUS MELO

**ANÁLISE DA DIFUSÃO DE *MALWARE* EM *HONEYPOTS*
DE BAIXA INTERATIVIDADE
NEPENTHES X *DIONAEA***

Orientador
Prof. Ruy Flávio de Oliveira

**ESPECIALIZAÇÃO EM TECNOLOGIA DE INFORMAÇÃO
CURSO DE SEGURANÇA DA INFORMAÇÃO**

SÃO JOSÉ DOS CAMPOS
COMANDO-GERAL DE TECNOLOGIA AEROESPACIAL
INSTITUTO TECNOLÓGICO DE AERONÁUTICA

2011

Dados Internacionais de Catalogação-na-Publicação (CIP)
Divisão de Informação e Documentação

Melo, Milton de Jesus
Análise da Difusão de *Malware* em *Honeypots* de Baixa Interatividade – *Nepenthes* x *Dionaea* / Milton de Jesus Melo.
São José dos Campos, 2011.
Número de folhas no formato 97f.

Trabalho de Conclusão de Curso – Especialização em Tecnologia da Informação. Curso de Segurança da Informação – Instituto Tecnológico de Aeronáutica, 2011. Orientador: Prof. Ruy Flávio de Oliveira.

1. *Nepenthes*. 2. *Dionaea*. 3. *Honeypots*. II. Comando-Geral de Tecnologia Aeroespacial. Instituto Tecnológico de Aeronáutica.

REFERÊNCIA BIBLIOGRÁFICA

MELO, Milton de Jesus. **Análise da Difusão de *Malware* em *Honeypots* de Baixa Interatividade – *Nepenthes* x *Dionaea***. 2011. Total de folhas 97. Trabalho de Conclusão de Curso (Especialização em Segurança da Informação) – Instituto Tecnológico de Aeronáutica, São José dos Campos.

CESSÃO DE DIREITOS

NOME DO AUTOR: Milton de Jesus Melo

TÍTULO DO TRABALHO: Análise da Difusão de *Malware* em *Honeypots* de Baixa Interatividade – *Nepenthes* x *Dionaea*

TIPO DO TRABALHO/ANO: Curso de Especialização / 2011

É concedida ao Instituto Tecnológico de Aeronáutica permissão para reproduzir cópias deste trabalho de curso e para emprestar ou vender cópias somente para propósitos acadêmicos e científicos. O autor reserva outros direitos de publicação e nenhuma parte desta monografia pode ser reproduzida sem a autorização do autor.

Milton de Jesus Melo
Rua Brás Cubas, 253 – Jardim Vitória.
Caieiras – SP – 07700-000

**ANÁLISE DA DIFUSÃO DE *MALWARE* EM *HONEYPOTS* DE BAIXA
INTERATIVIDADE – *NEPENTHES* X *DIONAEA***

Esta publicação foi aceita como Relatório Final do Curso de Segurança da Informação.

Prof. Ruy Flávio de Oliveira
Orientador

Prof. Sérgio Pellegrino
Coordenador do Curso de Pós Graduação em Segurança da Informação

Carmen Lúcia Ruybal dos Santos
Pró-Reitor de Extensão e Cooperação

ITA
São José dos Campos, 19 de Março de 2011

Dedico este trabalho aos meus pais, José Aristides e Maria da Conceição, pela dedicação, esforço, apoio e compreensão dados à minha formação como cidadão; à minha esposa, Renata Melo, e meu pequeno filho, Nickolas, que compartilham comigo todos os momentos de alegrias e tristezas em minha vida pessoal e principalmente no decorrer desta etapa que foi extremamente importante em minha vida acadêmica.

AGRADECIMENTOS

Agradeço em primeiro lugar a Deus, por abrir milhares de portas que indicaram o caminho certo para que eu pudesse elevar minha pessoa e meu conhecimento; à minha família, por me apoiar em todos os momentos; aos funcionários da Stefanini, pela dedicação e trabalho de apoio aos alunos; aos professores do curso de Pós-Graduação do ITA, pela dedicação, esforço e decência; e em especial ao meu orientador, Prof. Ruy, por encorajar e dar todo o apoio e dicas necessárias para o desenvolvimento desta pesquisa.

*“Conheça o inimigo e a si mesmo e você obterá a vitória
sem qualquer perigo.”*

SUN TZU

RESUMO

Invasão a computadores pessoais, vandalismo, realização de atividades ilegais e diversão são alguns dos diversos motivos que levam uma pessoa a invadir, explorar e comprometer um sistema computacional conectado a uma rede. Nessa guerra, o uso de sistemas de *Honeypots* tem se mostrado eficiente na coleta, análise e identificação de diversas técnicas e tipos de detecção de invasão em sistemas computacionais e na difusão de *software* maliciosos. Este trabalho é o resultado de uma pesquisa que visa à avaliação de ferramentas que utilizam a tecnologia de *Honeypots* com o objetivo de implantar, coletar e analisar informações de dois diferentes sistemas, utilizando uma abordagem experimental em um ambiente real de gerenciamento de *Honeypots* de baixa interatividade. Foi testada e comparada a eficiência dos *Honeypots* relacionada especificamente à coleta de *malware*, programas que têm por objetivo principal a execução de atividades maliciosas em redes computacionais conectadas diretamente à internet.

Palavras-chave: *Honeypots*. *Malware*. Internet. Programas. *Dionaea*. *Nepenthes*.

ABSTRACT

The invasion of personal computers, vandalism, carrying out illegal activities and entertainment are some of the many reasons that lead people to hack, exploit and compromise a computer system connected to a network. In this war, the use of systems Honeypots can be efficient in collecting, analyzing and identifying the many techniques and types of intrusion detection in computer systems and the dissemination of malicious software. This study is the result of a research aimed to evaluate tools that use the technology of honeypots in order to deploy, collect and analyze information from two different systems, using an experimental approach, in a real environment management Honeypots low interactivity. It was tested and compared the efficiency of the Honeypots specifically related to the malware collect, programs that the main objective is the execution of malicious activity in computer networks connected directly to the internet.

Keywords: Honeypots. Malware. Internet. Software. Dionaea. Nepenthes.

LISTA DE ILUSTRAÇÕES

FIGURAS

Figura 1-1 – <i>Honeypot</i> independente tradicional	25
Figura 2-1 – <i>Timeline</i> – Evolução dos <i>Honeypots</i>	25
Figura 3-1 – <i>Honeynet</i>	31
Figura 4-1 – A evolução dos <i>malware</i>	34
Figura 5-1 – Diagrama de ataque <i>DDoS</i>	37
Figura 1-2 – Conceito por trás do núcleo do <i>Nepenthes</i>	45
Figura 2-2 – Conceito por trás do núcleo do <i>Dionaea</i>	50
Figura 3-2 – Ilustração da topologia proposta	60
Figura 1-3 – Exemplo de consulta ao <i>SQLite</i> do <i>Dionaea</i> usando o <i>script</i> readlogsqtree.py	65
Figura 2-3 – Top 5 dos <i>malware</i> coletados pelos <i>honeypots</i>	68
Figura 3-3 – Classificação dos países de origem dos ataques	71
Figura 4-3 – Top 10 das portas exploradas	73
Figura 5-3 – Gráfico de linhas – <i>Dionaea</i> - Período vs. Volume de dados	74
Figura 6-3 – Gráfico de linhas – <i>Nepenthes</i> - Período vs. Volume de dados	75
Figura 7-3 – Gráfico de barras ilustrando as estatísticas dos códigos binários coletados	76

QUADROS

Quadro 1 – Principais diferenças entre <i>Honeypots</i> de baixa e alta interatividade	29
Quadro 2 – Teste de <i>port scanner</i> efetuado para verificar os filtros de cada operadora	38-39
Quadro 3 – Estrutura de portas e vulnerabilidades usada pelo núcleo do <i>Nepenthes</i>	42-43
Quadro 4 – Estrutura de portas e vulnerabilidades usada pelo núcleo do <i>Dionaea</i>	49

Quadro 5 – Ilustração do uso de <i>nouid</i> e <i>noexec</i> dentro do arquivo <i>fstab</i>	53
Quadro 6 – Ilustração da implantação do nível de segurança do <i>Kernel</i>	55
Quadro 7 – Exemplo do comando usado para transferência segura dos <i>logs</i>	61
Quadro 8 – Exemplo do uso do <i>firewall</i> no sensor <i>Nepenthes</i>	62
Quadro 9 – Exemplo do uso da ferramenta <i>tcpdump</i> para gerar <i>log</i> de conteúdo	62
Quadro 10 – Dados sobre o primeiro <i>malware</i> coletado	67
Quadro 11 – Dados sobre o “ <i>Malware Zero Day</i> ” coletado	70

TABELAS

Tabela 1 – Exemplo de aplicação dos atributos <i>nosuid</i> e <i>noexec</i>	53
Tabela 2 – Os 10 endereços IP que mais fizeram requisição no <i>Honeypot Nepenthes</i>	72
Tabela 3 – Os 10 endereços IP que mais fizeram requisição no <i>Honeypot Dionaea</i>	72

LISTA DE SIGLAS

3G:	Terceira Geração.
ABNT:	Associação Brasileira de Normas Técnicas.
ADSL:	Asymmetric Digital Subscriber Line.
API:	Application Program Interface.
CPU:	Central de Processamento de dados Unificada.
CVE:	Common Vulnerabilities and Exposures.
DoS:	Denial of Service.
DDoS:	Distributed Denial of Service.
DTK:	Deception Toolkit.
FTP:	File Transfer Protocol.
HTML:	HyperText Markup Language.
HTTP:	HyperText Transfer Protocol.
IDS:	Intrusion Detection System.
IPS:	Intrusion Prevention System.
IP:	Internet Protocol.
IPv4:	Internet Protocol Version 4.
IPv6:	Internet Protocol Version 6.
IRC:	Internet Relay Chat.
ISO:	International Organization for Standardization.
LAN:	Local Area Network
MSSQL:	Microsoft Structured Query Language
NFS:	Network File System.
NIS:	Network Information Service.

<i>NTP:</i>	Network Time Protocol.
<i>POSIX:</i>	Portable Operating System Interface.
<i>RAM:</i>	Random Access Memory.
<i>RPC:</i>	Remote Procedure Call.
<i>RTP:</i>	Real Time Protocol.
<i>SSH:</i>	Secure Shell.
<i>SIP:</i>	Session Initiation Protocol.
<i>SMB:</i>	Server Message Block.
<i>SSA:</i>	Cidade de Salvador.
<i>TCC:</i>	Trabalho de Conclusão de Curso.
<i>TCP:</i>	Transmission Control Protocol.
<i>TDS:</i>	Tabular Data Stream.
<i>TFTP:</i>	Trivial File Transfer Protocol.
<i>TLS:</i>	Transport Layer Security.
<i>UDP:</i>	User Datagram Protocol.
<i>VoIP:</i>	Voice over IP.

SUMÁRIO

INTRODUÇÃO	17
PROBLEMA.....	22
OBJETIVOS.....	22
1. HONEYPOTS	24
1.1. Breve história dos <i>Honeypots</i>	25
1.2. Classificação de <i>Honeypots</i>	27
1.3. Tipos de <i>Honeypots</i>	30
1.4. <i>Honeynets</i>	30
1.5. Requisitos das <i>Honeynets</i>	31
1.6. Utilização da tecnologia de <i>Honeypots</i>	33
1.6.1. Coleta e Detecção de <i>Malware</i>	33
1.6.2. Pesquisa, estudo e entendimento de técnicas de invasão	34
2. PROJETO CIENTÍFICO	38
2.1. Proposta.....	40
2.2. <i>Nepenthes</i>	40
2.2.1. Arquitetura do <i>Nepenthes</i>	41
2.2.2. Emulação de <i>shell</i>	45
2.3. <i>Dionaea</i>	46
2.3.1. Arquitetura do <i>Dionaea</i>	46
2.4. <i>Hardening</i>	51
2.4.1. Acesso remoto	52
2.4.2. Sistema de arquivos	52
2.4.3. <i>Kernel</i>	54

2.4.4. Atualizações e <i>patches</i> de segurança	55
2.4.5. <i>Hardenings</i> diversos	57
2.5. Ambiente experimental	57
2.6. Descrição do ambiente experimental	59
3. ANÁLISE DOS DADOS	63
3.1. Ferramentas utilizadas para análise dos dados	63
3.2. Estatísticas dos tipos de <i>malware</i> coletados	65
3.3. O primeiro <i>malware</i>	67
3.4. <i>Malware</i> mais coletados	68
3.5. Origem dos incidentes.....	71
3.6. IP de Origem <i>versus</i> Requisições de acesso	72
3.7. Portas exploradas	73
3.8. Estudo geral dos ataques.....	74
3.9. Estatísticas dos binários coletados – <i>Nepenthes</i> vs <i>Dionaea</i>	76
CONCLUSÃO	77
TRABALHOS FUTUROS	79
REFERÊNCIAS.....	80
GLOSSÁRIO.....	82
APENDICE A	86
APENDICE B	88
ANEXO A.....	92

INTRODUÇÃO

Atualmente, a preocupação com o valor da informação tem se tornado um fator muito importante para usuários de computadores, seja em um ambiente corporativo ou em um ambiente doméstico (FONTES, 2008). A evolução da tecnologia voltada à internet e o crescimento contínuo da utilização dos seus recursos e ferramentas possuem uma dependência muito grande de aplicações conhecidas como firewall, antivírus, anti-spyware, entre outras, que têm como objetivo a proteção de dados e informações (FONTES, 2008).

Para formação dessas proteções, são necessárias sérias pesquisas com foco em mecanismos de detecção de ataques ou qualquer outro tipo de atividade maliciosa no âmbito computacional realizadas por profissionais especializados no ramo de segurança da informação, que visam contribuir para a disseminação do conhecimento e a evolução de ferramentas para proteção.

O Centro de Estudos, Resposta e Tratamento de Incidentes de Segurança no Brasil (CERT.br) é um exemplo de instituição que desenvolve projetos de pesquisa e análises de tendências de ataques no espaço de internet no Brasil. É detentor da coordenação de um projeto de *Honeypots* que tem como principal objetivo “*aumentar a capacidade de detecção de incidentes, correlação de eventos e determinação de tendências de ataques no espaço de internet brasileiro*” (CERT.br, 2010).

Atrás desse conhecimento, este projeto científico busca o entendimento relacionado às técnicas e ferramentas utilizadas na Internet para disseminação automática de códigos maliciosos, adotando a postura da criação de um ambiente experimental para testes, através de sistemas conhecidos como *Honeypots* em certo grau de interatividade, desenvolvidos com objetivo principal de detectar, analisar e acompanhar as atividades ilícitas e técnicas usadas por essas aplicações.

A tendência inicial da pesquisa visava apenas o conhecimento de um cenário de *Honeypots* distribuídos utilizando o *Nepenthes* como principal ferramenta, monitorando os sistemas comuns de banda larga, *ADSL*, *Cable Modem* e *3G*. Com um volume de dados e estatísticas iniciais baixas, as expectativas ao longo da pesquisa foram sendo alteradas e a formação de novos critérios e cenários foram formados. O projeto evoluiu, o grau de dificuldade e compreensão das ferramentas foi aumentando e a pesquisa gerou volume, não só de conhecimento, mas também em relação aos dados coletados e estatísticas geradas pelos *Honeypots*.

Ao longo da pesquisa pode-se encontrar uma série de informações teóricas sobre a história, tipos e esclarecimentos sobre *Honeypots*, um breve estudo sobre tipos de ataques e atacantes, técnicas computacionais utilizadas para garantir a segurança do sistema operacional, conhecida como *Hardening*, documentação sobre a estrutura e funcionamento do *Nepenthes* e *Dionaea* e, por fim, uma documentação clara e objetiva sobre o ambiente experimental criado para coletar os códigos maliciosos.

Uma das metas alcançada foi a coleta de um “*Malware Zero-day*”, um código malicioso recém-lançado que tem sua assinatura ainda desconhecida pelos programas de antivírus. O ambiente experimental montado permitiu a captura do binário e encaminhamento de seu código para análise em ferramentas de testes discriminadas neste documento.

Os resultados apresentados nesta pesquisa poderão colaborar na orientação e conscientização do uso de ferramentas adequadas para proteção de sistemas computacionais usados para mitigação de riscos relacionados às informações gravadas em um computador. Sejam essas informações documentos importantes de uma empresa, fotos de momentos de família ou transações e dados bancários em um *site* de compras, elas têm que ser preservadas.

Para analisar a difusão de *malware* através de *Honeypots* de baixa interatividade, circunscrito à área de redes e segurança da informação, a presente pesquisa se organizou em três capítulos. O primeiro capítulo apresenta A Tecnologia de *Honeypots*, visando os conceitos gerais, histórico, classificação e principais características relacionadas a *Honeypots*. Em segundo lugar, está o núcleo desta pesquisa, com informações detalhadas e análise do ambiente experimental montado, bem como a descrição do funcionamento geral das ferramentas que foram utilizadas neste trabalho. Nesse capítulo, foi detalhada a forma nos quais foram instalados os sistemas operacionais, a utilização do método de *Hardening* usado em cada equipamento como medida de segurança básica para evitar que o sistema fosse invadido e usado como ferramenta para o *blackhat*, seguido pelo detalhamento das funcionalidades dos *frameworks* *Nepenthes* e *Dionaea* usados no cenário para emulação dos serviços de execução da coleta dos *malware*. Num terceiro momento, é apresentada a Análise e Comparação dos dados coletados por cada um dos *frameworks* citados, exibindo as estatísticas e informações dos relacionamentos dos dados coletados de cada uma. Por fim, têm-se as conclusões dos resultados obtidos nesta pesquisa, os quais foram levantados a partir de pesquisas efetuadas desde o início do curso até o período de feitura deste trabalho.

DELIMITAÇÃO DO TEMA

O tema se restringe ao tratamento das informações coletadas entre os *frameworks Nepenthes* e *Dionaea* em um ambiente experimental monitorado. O estudo do funcionamento de um *honeypot*, e as técnicas utilizadas para garantir a segurança do sistema operacional. Os *frameworks* foram instalados e executados com sua configuração padrão e não foram exploradas todas as suas funcionalidades, ficando limitada apenas a coleta automática do *malware*.

JUSTIFICATIVAS PARA A PESQUISA

Além do interesse pessoal do pesquisador, o tema se impõe pela recorrência das discussões sobre segurança na rede de Internet no Brasil, assunto obrigatório em todos os círculos no começo do século 21, e pela contribuição que uma pesquisa dessa natureza poder emprestar à compreensão do real papel do curso numa sociedade marcadamente composta de pessoas carentes de formação acadêmica e profissional, além de um crescente número de desempregados.

Há total relevância científica neste projeto de pesquisa uma vez que a segurança da informação no Brasil ainda é de extrema importância, sendo o assunto, porém, cheio de obscuridades, com escassez de profissionais qualificados não apenas de conhecimento e práticas teóricas, bem como na utilização de ferramentas essenciais “nesse campo de batalha”. A pesquisa pode servir de base para a difusão do conhecimento adquirido pela ferramenta, sendo uma das primeiras pesquisas no Brasil que utilizam o *Honeypot Dionaea*.

Além disso, há relevância social da pesquisa, que se mostra pelo fato de que o estudo permitirá ajudar na resposta a uma pergunta básica: justifica-se a atualização tecnológica de ferramentas de *Honeypots* no Brasil? Ao mesmo tempo, a pesquisa poderá ajudar a compreender qual o nível de eficiência que os *Honeypots* de baixa interatividade *Nepenthes* e *Dionaea* possuem para captura de *softwares* maliciosos.

Nosso interesse pessoal advém do fato de militarmos na área de segurança de redes computacionais, interessando-nos grandemente o desafio de poder criar um ambiente experimental com sucesso, principalmente quanto nossa postura em prol de nos envolvermos mais efetivamente com o objeto de nossa investigação.

O tema se mostra de execução viável, primeiro pela existência de fontes a serem consultadas; segundo, pelo apoio que recebemos da instituição e pelos estudos teóricos já desenvolvidos nessa área.

REFERENCIAL TEÓRICO

São aqui apontados não apenas os textos existentes até o momento, como são analisados os progressos, resultados, conclusões e limitações que ora se apresentam. Segue, portanto, uma relação do que se tem pesquisado com vistas à elaboração deste trabalho de conclusão de curso (TCC), tanto no aspecto da apresentação do estado atual da questão, como propriamente o referencial teórico empregado na pesquisa (marco teórico).

Foi de grande utilidade para a pesquisa o livro “Conheça seu inimigo – O projeto *honeynet*”, de Addison e Wesley, que apresenta uma síntese de técnicas e ferramentas de segurança abordadas em uma rede de *Honeypots*, informações sobre análises de dados, táticas e motivações dos invasores e um passo a passo para estudar as técnicas utilizadas pela comunidade *underground*.

Marcelo e Pitanga organizaram o livro “Honeypots – A arte de iludir hackers”, no qual explicam um estudo sobre a tecnologia de *Honeypots* com o objetivo de divulgar tipos de ataques utilizando diversas ferramentas de *Honeypots* conhecidas.

Melo, Domingos, Correia e Maruyama apresentam o texto “BS7799 – Da tática à prática em servidores Linux”, em que abordam o tema de *Hardening* e oferecem uma visão de implementação de controles com a finalidade de proteção do sistema operacional, bem como apoio às boas práticas de segurança da informação em conformidade com a Norma ABNT NBR ISO/IE 17799, de 2005.

O paper “*The Nepenthes Platform: An eficiente approach to collect malware*” de Baecher, Koetter, Holz, Dornseif e Freiling, um dos documentos mais importante e relevante utilizado na pesquisa, trata-se de um documento criado pelos desenvolvedores do *Nepenthes* e traz informações detalhadas sobre o *framework* e seu funcionamento, informações não encontradas na documentação da aplicação.

A análise dos dados foi obtida mediante a coleta de dados criados a partir de um ambiente experimental elaborado por nós. Secundariamente, com apoio teórico, foram consultados os textos citados na lista final de referências, posto que são artigos, normas e documentos indispensáveis à compreensão prévia do problema desta pesquisa.

PROBLEMA

A pesquisa foi realizada a partir do seguinte problema central: *Nepenthes* ou *Dionaea*? Qual *Honeypot* é mais efetivo na análise da difusão de *malware*?

OBJETIVOS

Para a apresentação mais clara dos objetivos dessa pesquisa, a problemática (questão central) norteadora da pesquisa, bem como a hipótese deste trabalho, foram o “fio de Ariadne”, em fase de apresentação para a banca examinadora. A partir da questão central, o objetivo deste TCC é:

- Criar um ambiente controlado e altamente monitorado para análise e avaliação dos *frameworks Nepenthes* e *Dionaea*, *Honeypots* de baixa interatividade, efetuando a detecção e coleta de programas maliciosos conhecidos como *malware*, difundidos pela rede mundial de computadores, a Internet, utilizando uma abordagem totalmente experimental, observando-se suas características de ataques, autopropagação, vulnerabilidades exploradas e avaliação dos arquivos binários (executáveis) que foram capturados pelo sistema.

PROCEDIMENTOS METODOLÓGICOS

A pesquisa seguiu etapas próprias, a partir da hipótese norteadora. Para a coleta dos dados foram necessários instrumentos adequados, bem como foram empregadas técnicas aprendidas durante o curso de Segurança da Informação para a efetiva análise dos dados coletados. Foram, portanto, adotados os seguintes procedimentos:

- a) leitura de textos de orientação teórico-metodológica;
- b) pesquisa documental e bibliográfica;
- c) observação passiva, análise e interpretação dos dados.
- d) análise geral dos resultados.

Capítulo 1

1. HONEYPOTS

A introdução do conceito de *Honeypots* começou através do astrofísico Clifford Stoll, um administrador de sistemas de um laboratório do governo americano no final da década de 1980, após ter descoberto um usuário não autorizado que vinha utilizando os computadores do escritório. Após isso, começou um grande trabalho de perseguição do *blackhat*, sua dedicação e história acabaram virando um livro, “*The Cuckoo’s Egg*” (STOLL, 1988), hoje *best seller*, no qual descreve sua caçada muito bem-sucedida utilizando técnicas do tipo *Jail* para capturar a sessão do invasor. Para isso simulou um projeto governamental completo, no qual os invasores gastaram horas baixando e analisando, fato que ofereceu a oportunidade para que os invasores fossem rastreados.

O termo *Honeypot* foi introduzido no mundo computacional em 1999 por Lance Spitzner. A palavra vem do termo “pote de mel”, que na antiguidade era um produto cobiçado por nobres e reis pela sua doçura, o mesmo conceito hoje usado para o recurso de *Honeypot*, ou seja, ser um elemento atraente e extremamente cobiçado pelos invasores (MARCELO; PITANGA, 2003).

Uma das definições mais clássicas e claras sobre o que é um *Honeypot* foi dada por Spitzner (2003): “*Um Honeypot é um recurso de rede cuja função é ser atacado e comprometido (invadido). Significa dizer que um Honeypot poderá ser testado, atacado e invadido*” (apud MARCELO; PITANGA, 2003).

Em suma, podemos caracterizar o *Honeypot* como um ou mais sistemas que fornecem elementos atraentes utilizados para invasão de um *blackhat* (Figura 1-1), sendo necessário monitorar com precisão toda e qualquer atividade e interação feita por ele, para que o sistema não possa ser comprometido (MARCELO; PITANGA, 2003), pois um sistema de *Honeypot* comprometido torna-se inútil e vira uma ferramenta para uso pessoal do *blackhat* (ADDISON; WESLEY, 2002).

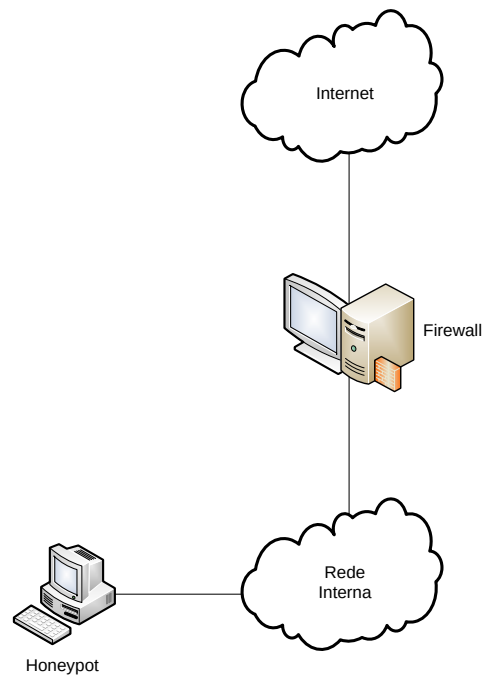


Figura 1-1 – *Honeytrap* independente tradicional (ADDISON e WESLEY, 2002, p. 10)

1.1. Breve história dos *Honeytraps*

A figura 2-1 abaixo mostra um resumo de linha do tempo da evolução dos *Honeytraps*. Foram citados apenas os mais relevantes para esta pesquisa.

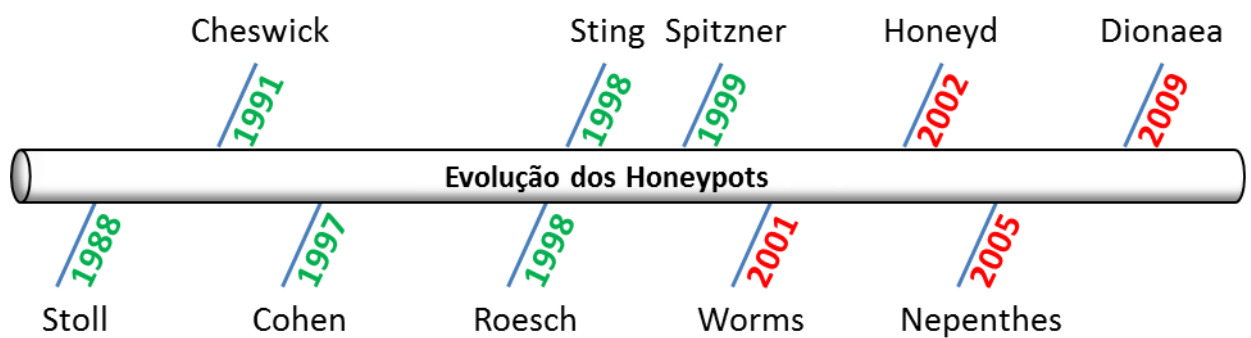


Figura 2-1 – *Timeline* – Evolução dos *Honeytraps*
(Elaborada pelo autor)

- a) **1998 – Clifford Stoll:** autor do *best seller* “*The Cuckoo’s Egg*”, ficou famoso por divulgar sua experiência na caçada pelo *blackhat* Hunter utilizando técnicas usadas pelos *Honeypots* atuais.
- b) **1991 – Bill Cheswick:** autor do *paper* “*An Evening with Berferd*”, que narra seus estudos e técnicas utilizadas para encurralar o *blackhat* Berferd, usando um *bug* no *Sendmail* para obter as senhas do sistema.
- c) **1997 – Fred Cohen:** criador do *software* livre DTK – *Deception Toolkit*, considerado o primeiro *Honeypot*, um conjunto de *scripts* que simulam servidores e vulnerabilidades.
- d) **1998 – Sting:** primeiro *Honeypot* comercial criado pela empresa Cybercop para o Windows NT; simulava serviços de rede emitindo respostas falsas para os invasores.
- e) **1998 – Martin Roesch:** idealizador e pai do *Snort*, um sistema de detecção de intrusos, programou para o governo americano um *Honeypot* que simulava uma rede classe C com diferentes tipos de sistemas operacionais simulados com diversos serviços de rede.
- f) **1999 – Lancer Spitzner:** uma das datas mais importantes na linha do tempo, Spitzner criou o Projeto *Honeynet*, mobilizando mais de 30 especialistas em segurança. Desenvolveu diversas metodologias em *Honeypots* e é auto do livro “*Honeypots Tracking Hackers*”, sendo uma das maiores referências no assunto.
- g) **2001 – Worms:** utilizados por diversas empresas, em 2001 os *Honeypots* passaram a capturar diversos *worms*, tais como *CodeRed II* e o *W32/LeavesWorm*, difundidos pela Internet.
- h) **2002 – Honeyd:** lançamento do *software open source* “*Honeyd*”, criado por Niels Povel. É um *Honeypot* de baixa interatividade, muito utilizado nos dias de hoje, principalmente no Consórcio Brasileiro de *Honeypots*, projeto de distribuição de sensores em redes brasileiras mantido pela CERT.br.

- i) **2005 – *Nepenthes***: lançamento do *software open source* “*Nepenthes*”, *Honeypot* de baixa interatividade.
- j) **2009 – *Dionaea***: lançado em 2009 e ainda em contínuo desenvolvimento, o *Dionaea* é um *Honeypot* de baixa interatividade criado com o intuito de substituir o *Nepenthes*.

1.2. Classificação de *Honeypots*

Segundo Marcelo e Pitanga (2003), os *Honeypots* podem ser classificados em diversos tipos. Sua variação depende do contexto no qual são aplicados, ou seja, sua implementação depende de seu objetivo final.

Para escolha de um *Honeypot* devem ser consideradas as classificações em comum encontradas nas literaturas sobre o assunto (MARCELO; PITANGA, 2003 apud SPITZNER; BAUMANN; NORTHENT, 2002), usando-se como critério principal o nível de interatividade, tipo de estrutura e, principalmente, seu objetivo final. Devem ser consideradas também questões relacionadas à instalação, configuração, desenvolvimento, manutenção, coleta de informações e nível de risco.

- a) ***Honeypots* de baixa interatividade**: com seu nível de interatividade limitado, incitado pelo seu próprio termo, esse tipo de sistema utiliza como principal recurso a emulação de serviços falsos, registrando apenas as conexões. Neste nível de interatividade o *Honeypot* é de muito fácil instalação e manutenção e oferece um baixo risco aos recursos e operações produzidos pela ferramenta; por outro lado, as informações coletadas pelo sistema são limitadas e na maioria dos casos são capazes apenas de registrar o tempo e a data da tentativa da conexão. Por fim, o objetivo principal de um *Honeypot* de baixa interatividade é detectar e logar tentativas de conexões não autorizadas.

Como exemplos de ferramentas comuns utilizadas neste nível de interatividade podem ser citados o *Tiny Honeypot* e o *Deception Toolkit*.

- b) **Honeypots de média interatividade:** neste nível de interatividade o *honeypot* passa a capturar uma maior gama de informações e dados sobre o ataque. Apesar de utilizar o mesmo conceito de emulação de falsos serviços de rede, a ferramenta passa a fornecer serviços mais sofisticados, respondendo às requisições do atacante, simulando *bugs* e vulnerabilidades de um sistema real. A técnica e método utilizado neste tipo de *honeypot* são conhecidos como *Jail* ou *Chroot* (CHESWICK, 1992), no qual o atacante poderá rodar um *script* ou *malware* no ambiente e sua sessão ficará aprisionada, criando a ilusão que o sistema foi invadido. Com isso é possível estudar as técnicas e aplicações usadas pelo invasor. Neste nível de interatividade existe um risco maior, uma vez que o invasor pode encontrar uma falha na segurança da aplicação e realmente invadir o sistema operacional, por isso, é necessário ter um conhecimento maior da tecnologia antes de implementar esse tipo de ambiente.

A maioria dos autores, incluindo Addison e Wesley (2002) e Baecher et alii (2006), prefere caracterizar os níveis apenas como baixa e alta interatividade, incluindo os que seriam de média interatividade, segundo seus critérios, como um *Honeypot* de baixa interatividade, e é o foco nessa abordagem de divisão que utilizamos nesta pesquisa.

Como exemplos de ferramentas comuns utilizadas neste nível de interatividade podemos citar o *Nepenthes* e o *Dionaea*.

- c) **Honeypots de alta interatividade:** neste nível de interatividade o *honeypot* passa a ter um risco muito maior que os demais apresentados, mas é por ter um risco tão alto que o sistema torna-se atraente para o invasor, pois o ambiente todo é montado em cima de um sistema computacional real, com seus serviços, funcionalidades e sistema operacional contendo vulnerabilidades reais, sem qualquer tipo de emulação. Essa metodologia traz grandes vantagens aos pesquisadores porque coleta muito mais informações de maior valor sobre o ataque e o atacante, mas é a estrutura que demanda mais tempo para ser implementada e suas atividades devem ser o tempo todo monitoradas para que

o sistema comprometido não se torne uma ponte para ataque a outros servidores ou se torne um repositório para o atacante, entre outras coisas.

A forma mais comum para empregar-se um ambiente com o nível de alta interatividade é utilizando as ferramentas de virtualização de sistemas operacionais tais como *VMWare* (VMWARE, 2010), *Hyper-V* (MICROSOFT, 2010). Como exemplos de ferramentas comuns utilizadas neste nível de interatividade, podemos citar *Honeywall open source*, disponível no *Honeynet Project* (SPITZNER), e o produto comercial da empresa Symantec *Decoy Server* (SYMANTEC, 2010).

No quadro a seguir foram resumidas e destacadas as principais diferenças entre as classificações dos *Honeypots* de baixa e alta interatividade:

BAIXA INTERATIVIDADE	ALTA INTERATIVIDADE
Emula sistemas operacionais, aplicações e serviços de rede.	Utilização de sistemas, aplicações e serviços de rede reais, sem emulação.
Fácil instalação e manutenção.	Instalação e manutenção complexa. É necessário um nível de conhecimento maior para administrar o sistema.
Risco baixo. A administração dos serviços emulados é mais fácil e é possível monitorar e controlar as ações do atacante	Risco alto. Mais difícil de controlar, uma vez que o ataque está sendo feito em um sistema com vulnerabilidades reais.
Captura limitada de informações.	Maior captura de informações e dados sobre o ataque e o atacante; em um sistema bem monitorado é possível capturar ataques desconhecidos.

Quadro 1 – Principais diferenças entre *Honeypots* de baixa e alta interatividade.

1.3. Tipos de *Honeypots*

Os *Honeypots* podem ser categorizados em dois tipos, estes apresentados por Martin Roesch (apud MARCELO; PITANGA, 2003):

- a) ***Honeypots de pesquisa***: este tipo de *Honeypot* tem como principal função coletar o máximo de informações possíveis relativas aos ataques e atacantes, permitindo acompanhar o ataque desde seu início, passo a passo, até sua conclusão. *Honeypots* de pesquisa normalmente são implementados com sistemas de alta interatividade, para que sejam registrados todos os passos e eventos do sistema. Este tipo de *Honeypot* deve ser protegido de forma correta, pois apresenta os mesmos riscos de equipamentos usados em produção real. São uma ferramenta educacional e acadêmica devido à plataforma permitir o estudo e o entendimento das ameaças virtuais da comunidade *underground*.
- b) ***Honeypots de produção***: são *Honeypots* de baixa interatividade com o objetivo de ser uma ferramenta de segurança em uma organização. Sua finalidade é distrair atividades maliciosas de uma rede ou gerar alertas em conjunto com outras aplicações, tais como *Intrusion Detection System* (IDS) ou *Intrusion Prevention System* (IPS).

1.4. *Honeynets*

Segundo Addison e Wesley (2002), uma *Honeynet* é uma rede de *Honeypots* de alta interatividade, altamente controlada e observada de sistemas computacionais múltiplos (Figura 3-1) projetados com o intuito de serem comprometidos pela comunidade *underground* (os *blackhats*), cuja principal finalidade é ser uma ferramenta de pesquisa e utilizada para aprender o uso das ferramentas, técnicas, táticas e motivos da comunidade *underground*. Todo o tráfego de entrada e saída é monitorado, capturado e analisado posteriormente.

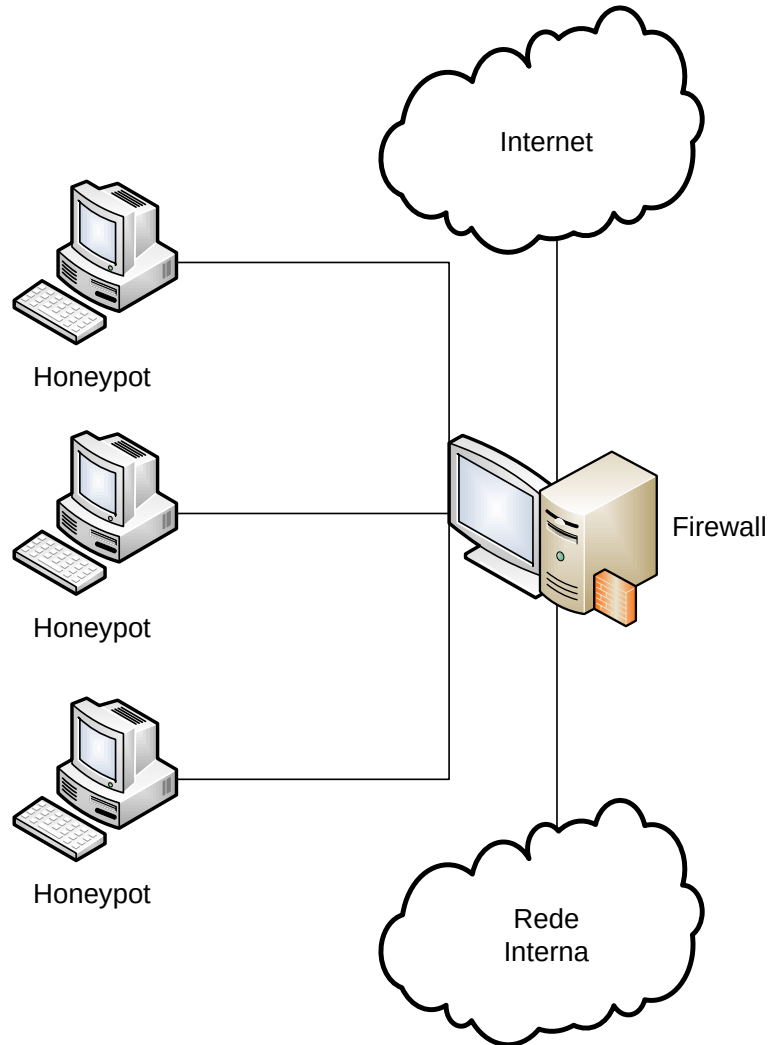


Figura 3-1 – *Honeynet* (ADDISON; WESLEY, 2002).

1.5.Requisitos das *Honeynets*

Segundo Addison e Wesley (2002):

“A criação e a manutenção de uma *Honeynet* bem sucedida dependem de dois elementos críticos: o controle de dados e a captura de dados”

Sobre este controle e essa captura temos:

- a) **Controle de dados:** um fator crítico que se baseia em atenuação do risco da *Honeynet* ser comprometida. O administrador tem a responsabilidade de garantir que o sistema não seja utilizado para atacar sistemas de produção de outras redes. Tendo em vista que *Honeynets* são *Honeypots* de alta

interatividade, os atacantes estarão interagindo com sistemas reais, tendo total liberdade para realizar suas atividades. Para manter tais controles, é necessário fazer um estudo para implantar mecanismos que garantam a segurança sobre o sistema, o que pode ser feito através de *firewalls*, *IDS*, servidor de *logs* (ADDISON; WESLEY, 2002).

- b) **Captura de dados:** neste elemento temos a coleta de todos os registros das atividades feitas pelo atacante na *Honeynet*. Essas informações formam a base para o núcleo da análise e pesquisa. Este requisito tem um papel importante, porque é a finalidade principal de uma *Honeynet*, e não pode ter falha neste processo. “*O segredo do sucesso para a captura de dados são as camadas; quanto mais métodos de capturas de dados tivermos, melhor*” (ADDISON; WESLEY, 2002).

Ainda de acordo com Addison e Wesley (2002), as camadas de captura de dados são classificadas em quatro diferentes níveis. São eles:

- i. **Camada de controle de dados:** nesta camada estão discriminados dispositivos de controle de acesso, dentre eles *firewalls* ou roteadores, que de forma geral são a porta de acesso utilizada pela *Honeynet*. Todo pacote de entrada e saída deve passar através desses dispositivos, e por sua vez registrado em *logs*, de forma que possa ser analisado posteriormente;
- ii. **Camada de rede:** nesta camada são focados os elementos de captura e análise dos dados dos pacotes que trafegam na rede. As informações desta camada são divididas em dois tipos: **os alertas de assinatura suspeita** – processo de pesquisa de atividades suspeitas ou maliciosas nas assinaturas do pacote - e a **carga útil (*payload*) do pacote** – processo de análise dos dados que informa quais atividades estão ocorrendo na rede. Esta camada, combinada com um *IDS*, permite capturar todo o *payload* do pacote e enviar alertas para o administrador baseados nas assinaturas suspeitas.

- iii. **Camada de sistema:** nesta camada são abordadas as capturas de dados do sistema, tais como pressionamentos de teclas e atividades do próprio sistema. Esses dados, por questão de segurança, devem ser armazenados em um local remoto de forma segura. Um exemplo disso é a utilização do *daemon syslog*, com suporte à criptografia, para coletar e transferir os *logs* principais do sistema operacional para um servidor protegido, além de ser um ponto de coleta central para os *logs* da *Honeynet*.
- iv. **Camada off-line:** quando um sistema é comprometido, ele pode fornecer infinitas possibilidades de dados sobre o ataque e o atacante, como por exemplo, amostras de ferramentas, *scripts*, códigos binários, configurações do sistema usadas pelo *blackhat*. Um exemplo clássico dado por Addison e Wesley (2002) é fazer uma imagem do *Honeypot* usando o aplicativo *Tripwire* antes de colocá-lo em produção. Essa aplicação permite identificar os binários ou arquivos de configuração que foram alterados no sistema, possibilitando realizar uma análise *off-line* do ambiente comprometido e reconstruir as atividades executadas pelo atacante.

1.6.Utilização da tecnologia de *Honeypots*

As ferramentas de *Honeypots* têm sido empregadas em diversos cenários relacionados ao contexto de segurança da informação (MARCELO; PITANGA, 2003). Dentre eles se destacam:

1.6.1. Coleta e Detecção de *Malware*

Malware, provenientes do termo *malicious software*, são programas maliciosos que têm por objetivo causar danos ou roubos de informações em sistemas computacionais (TECHNET, 2011). Nesta categoria se destacam: *vírus*, *worms*, *trojans horses*, *spyware*, *backdoors*, *bots*, *rootkits*. Essas aplicações, em constante desenvolvimento, há anos são uma permanente ameaça para os computadores conectados em redes. Para se autopropagarem rapidamente e de forma autônoma em redes corporativas ou na internet, alguns desses programas causaram, e causam até hoje, prejuízos em diversas redes ao redor do globo.

Para se ter uma ideia da proporção do problema, no final de 2010 foi ultrapassada a marca dos 50 milhões de diferentes pragas virtuais identificadas no ciberespaço, segundo a organização AV-Test (MARX, 2011). A evolução exponencial desse número pode ser verificada no quadro abaixo:

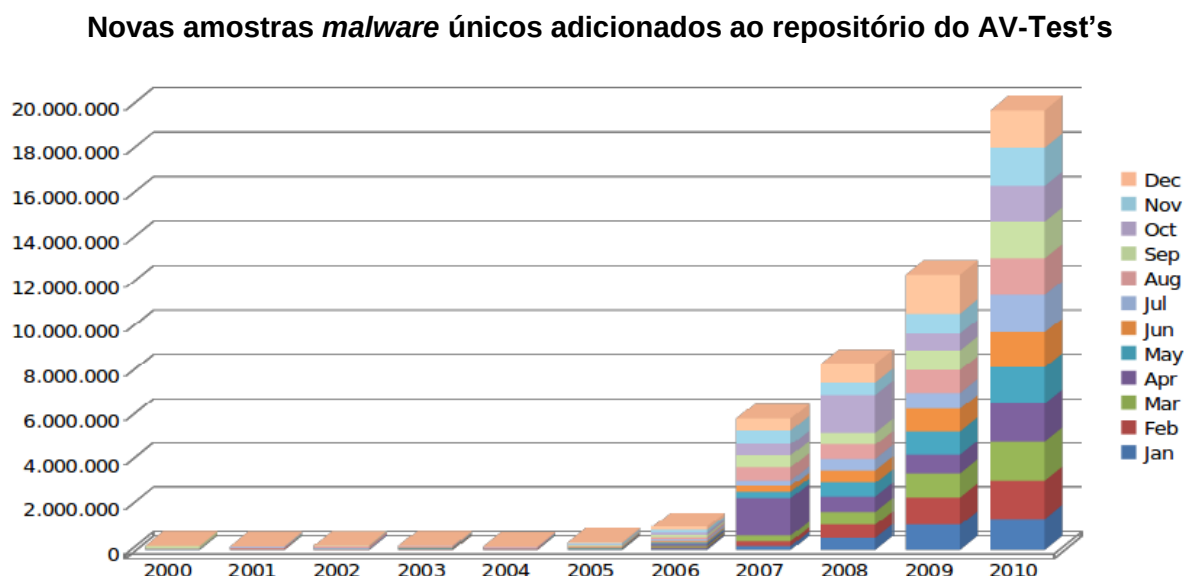


Figura 4-1 – A evolução dos *malware* (MARX, 2011)

Para cada um dos tipos de *malware* classificados, é recomendado um diferente tipo de *Honeypot*. Por exemplo: o *Nepenthes* e o *Dionaea*. *Honeypots* de baixa interatividade são indicados especificamente para coleta de *malware* que se difundem de forma automática.

Honeypots de alta interatividade devidamente controlados também possuem a capacidade de coletar *malware*. Nesse contexto encontram-se os mais novos ou conhecidos como *malware zero day*, *malware* com suas assinaturas ainda desconhecidas pelas aplicações que fornecem segurança aos sistemas computacionais, permitindo que os desenvolvedores de antivírus possam criar novas assinaturas em seus *software* para que sejam capazes de detectar comportamentos ou tráfegos maliciosos e proteger devidamente os seus sistemas.

1.6.2. Pesquisa, Estudo e Entendimento de Técnicas de Invasão

Como já citado neste documento, *Honeypots* de pesquisa podem trazer informações muito valiosas sobre o ataque e o atacante, tais como: endereço IP do atacante, serviços que foram conectados, ações que foram executadas no equipamento, arquivos que foram alterados, entre outras ações.

Tratando-se de *Honeypots* de pesquisa, existem muitos questionamentos que precisam ser respondidos para se conhecer profundamente um determinado incidente e um atacante. Dentre eles temos (ADDISON; WESLEY, 2002):

- a) **A ameaça:** o assunto “os atacantes”, em várias literaturas, tais como em Marcelo e Pitanga (2003), e em Addison e Wesley (2002), é comumente apresentado como ameaça para um ambiente computacional, e são classificados da seguinte forma:
 - i. **Script Kiddies/Lammer:** iniciantes no mundo *underground* que utilizam ferramentas desenvolvidas por terceiros para efetuarem seus ataques. Este tipo de invasor não possui conhecimentos avançados e pesquisa em tutoriais, ferramentas e vulnerabilidades já conhecidas para sondagem e exploração de um ataque fácil.
 - ii. **Blackhat:** conhecedor de sistemas operacionais, redes e suas fraquezas. É um indivíduo que utiliza a tecnologia para atividades ilegais, destrutivas ou não autorizadas (ADDISON; WESLEY, 2002).
 - iii. **Cracker:** usuário que detém conhecimentos profundos de sistemas operacionais e programação; utiliza como técnica a depuração de programas, pesquisa de vulnerabilidades em sistemas e criação de ferramentas para explorar as vulnerabilidades de um sistema para permitir a invasão.
 - iv. **Malware:** programas maliciosos de computador que têm por objetivo causar danos ou roubos de informações a sistemas computacionais, sendo elas confidenciais ou não.
 - v. **Usuário:** segundo Marcelo e Pitanga (2003), o usuário é considerado a maior de todas as ameaças. Por falta de conscientização, descuido ou até mesmo vingança, o usuário pode comprometer toda uma estrutura, seja ela corporativa ou doméstica.

- b) **As táticas:** ao longo dos anos, o “Projeto *Honeynet*” identificou que a comunidade *underground* tem usado a mesma tática, não se aplica a todos os tipos de tarefas, mas esta que citaremos na sequência é a mais simples e utilizada (ADDISON; WESLEY, 2002). O atacante varre diversos endereços de rede aleatoriamente procurando por um sistema que contém vulnerabilidades a serem exploradas. Uma vez que o endereço encontra-se com seu sistema respondendo às requisições, o atacante começa a reunir diversas informações sobre o endereço IP escolhido, como: qual o sistema operacional, os serviços e aplicativos que foram instalados e, principalmente, suas versões, o que normalmente determina se o serviço ou aplicação possui uma vulnerabilidade que possa ser explorada.
- c) **As ferramentas:** de posse das informações necessárias, o próximo passo da invasão é a escolha da ferramenta a ser usada pelo invasor para forçar uma anomalia no sistema e obter acesso administrativo ao sistema comprometido. O estudo dos princípios gerais dos ataques pode ser dividido nas seguintes classes (MARCELO; PITANGA, 2003):
- i. **Ataques de exploração:** são ataques que têm como objetivo principal explorar e coletar informações de *hosts* ativos na rede. Esse perfil de ferramenta é usado na primeira fase do ataque, e alguns deles trazem desde a identificação do sistema operacional (*fingerprint*) até um relatório geral de vulnerabilidades do sistema. Conhecidos como *scanners* de rede, existe diversas opções destas ferramentas *open source* para *download* disponível na Internet. Dentre eles podemos citar os mais comuns: *NMAP*, o *HPING* e o *NESSUS*.
 - ii. **Ataques de paralisação:** ataques conhecidos como *Denial of Service (DoS)* – Ataques de Negação de Serviço, e *Distributed Denial of Service (DDoS)* – Ataques de Negação de Serviços Distribuídos. São ataques que agem diretamente sobre a implementação da pilha do protocolo IP, utilizado para travar ou paralisar um equipamento de rede temporariamente, podendo ser

feito de forma individual (*DoS*) ou em grupo (*DDoS*). Neste, os equipamentos são administrados por *hosts* conhecidos como *Masters* ou *Manipulador*, que controlam uma série de outros nós, ou também conhecidos como *Daemons* ou *Agentes* - equipamentos de rede com vulnerabilidades já comprometidos pelo atacante - na Internet, no qual irão gerar o ataque (Figura 5-1).

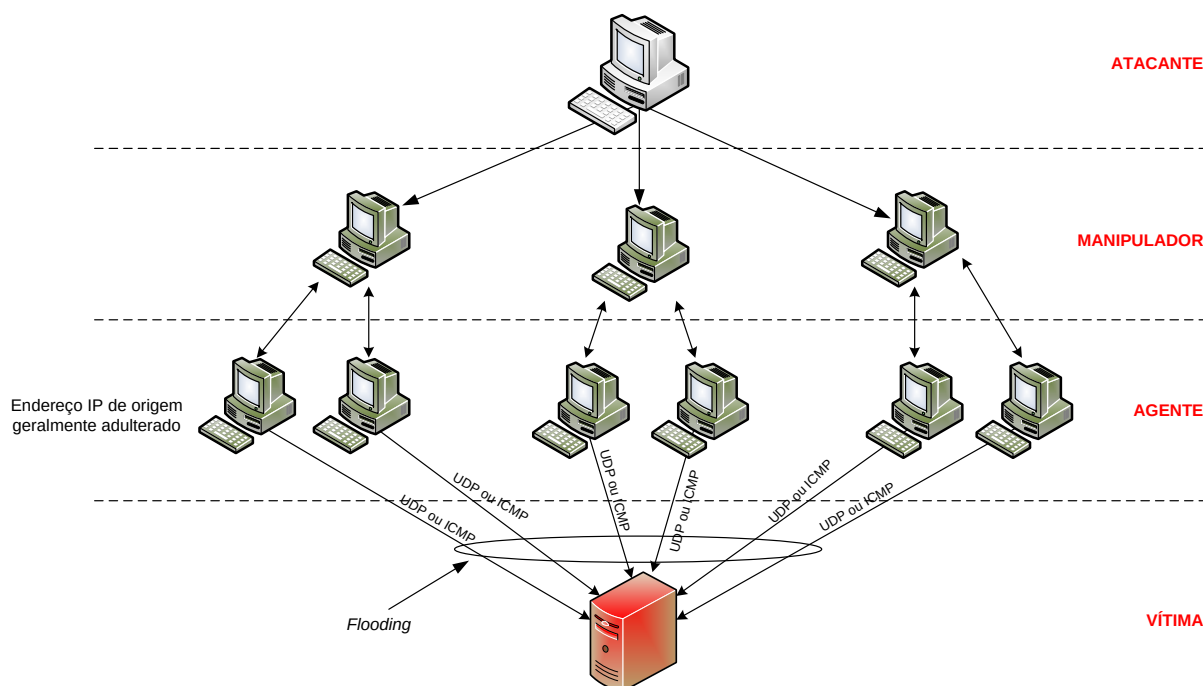


Figura 5-1 – Diagrama de um ataque DDoS (adaptado de CASTRO, 2011)

- iii. **Ataques de comprometimento:** ataques conhecidos como *buffer overflow*, que se baseiam na execução de programas ou *scripts* desenvolvidos com o objetivo exceder o *buffer*, uma área de memória limitada onde o computador armazena os dados, para que o atacante possa ter acesso ao *shell* do equipamento.

Capítulo 2

2. PROJETO CIENTÍFICO

Esta pesquisa foi baseada inicialmente na montagem de um laboratório utilizando-se *Honeypots* de baixa interatividade, a fim de obter uma análise de como são difundidos os *malware* em sistemas de banda larga. Foram colocados três sensores utilizando o *framework Nepenthes* em três distintos tipos de acesso à Internet: um *link ADSL* da operadora Telefônica/SP, um *link Cable Modem* da operadora Net/SP, e um *link 3G* da operadora Vivo/SP. Nessa primeira fase, o *deployment* foi iniciado em 15/09/2010 e ficou por cerca de três meses em atividade.

Antes de colocar o ambiente em produção, foram realizados testes de conectividade a partir de um *link* dedicado da operadora Embratel/SSA. Os testes indicaram que as operadoras de banda larga possuíam filtros que bloqueavam qualquer tentativa de acesso de algumas das portas padrões utilizadas pelo sensor para emulação dos serviços de rede, deixando apenas alguns serviços disponíveis na Internet conforme indica o Quadro 2:

PORTAS	STATUS	SERVIÇO	RAZÃO	FILTROS
21/tcp	<i>filtered</i>	<i>ftp</i>	<i>no-response</i>	
25/tcp	<i>filtered</i>	<i>smtp</i>	<i>no-response</i>	
42/tcp	<i>open</i>	<i>nameserver</i>	<i>syn-ack</i>	
80/tcp	<i>filtered</i>	<i>http</i>	<i>no-response</i>	
110/tcp	<i>open</i>	<i>pop3</i>	<i>syn-ack</i>	
135/tcp	<i>filtered</i>	<i>msrpc</i>	<i>no-response</i>	
139/tcp	<i>filtered</i>	<i>netbios-ssn</i>	<i>no-response</i>	
143/tcp	<i>open</i>	<i>imap</i>	<i>syn-ack</i>	
443/tcp	<i>filtered</i>	<i>https</i>	<i>no-response</i>	
445/tcp	<i>filtered</i>	<i>microsoft-ds</i>	<i>no-response</i>	
465/tcp	<i>open</i>	<i>smtps</i>	<i>syn-ack</i>	
993/tcp	<i>open</i>	<i>imaps</i>	<i>syn-ack</i>	
995/tcp	<i>open</i>	<i>pop3s</i>	<i>syn-ack</i>	

PORTAS	STATUS	SERVIÇO	RAZÃO	FILTROS
1023/tcp	open	netvenuechat	syn-ack	
1025/tcp	open	NFS-or-IIS	syn-ack	
2103/tcp	open	zephyr-clt	syn-ack	
2105/tcp	open	eklogin	syn-ack	
2107/tcp	open	unknown	syn-ack	
3372/tcp	open	msdtc	syn-ack	
5000/tcp	open	upnp	syn-ack	
6129/tcp	open	unknown	syn-ack	
10000/tcp	open	snet-sensor-mgmt	syn-ack	
27347/tcp	filtered	CounterStrike	no-response	
5554/tcp	open	unknown	syn-ack	
3140/tcp	open	unknown	syn-ack	
3127/tcp	open	unknown	syn-ack	
17300/tcp	open	kuang2	syn-ack	
2745/tcp	open	unknown	syn-ack	
220/tcp	open	imap3	syn-ack	
Legendas de Filtros:  ADSL  CABLE  3G				

Quadro 2 – Teste de Port Scanner efetuado para verificar os filtros de cada operadora

Essa fase experimental foi descartada e o projeto inicial foi inviabilizado por falta de dados coletados pelos sensores, um número muito baixo para ser relevante à pesquisa, isso devido às aplicações dos filtros das operadoras.

A segunda fase desta pesquisa foi tomar a decisão de moldar um novo cenário através do conhecimento adquirido da ferramenta, surgindo a necessidade de avaliar a eficiência do *Framework Nepenthes* com seu sucessor, *Dionaea*. A motivação deste novo cenário provém da curiosidade em saber o quanto avançou a tecnologia de honeypots de baixa interatividade, ao ponto do desenvolvedor criar um novo *framework* que aborda novas tecnologias de redes.

Nas próximas seções deste capítulo será detalhado o ambiente experimental criado. Serão também descritos cada um dos *frameworks* em maiores detalhes, bem como suas características e estratégias comuns para coleta de informações sobre os ataques dos *software* maliciosos.

Este capítulo tem como finalidade apresentar uma visão clara sobre as ferramentas e suas funcionalidades, as metodologias e processos de segurança da informação utilizados para garantir a segurança do sistema. Contudo, apesar de apresentar informações detalhadas sobre os *frameworks*, nem todas as funcionalidades foram testadas no ambiente experimental, e a metodologia usada foi apenas focada na coleta para análise da difusão de *malware* na Internet.

2.1.Proposta

A proposta final desta pesquisa foi focada na montagem de um ambiente computacional utilizando os *frameworks* *Nepenthes* e *Dionaea* para comparação da eficiência das aplicações sob o ponto de vista de coleta e análise da difusão de *malware* na Internet. Na decorrência da coleta dos ataques, seus resultados serão apresentados e discutidos em termos quantitativos.

Com base nessa proposta foram definidos os seguintes objetivos:

- a) Estudo e funcionamento do *framework* *Nepenthes*;
- b) Estudo e funcionamento do *framework* *Dionaea*;
- c) Estudo, funcionamento e aplicação de técnicas de *Hardening*;
- d) Implantação do sistema de *Honeypot*;
- e) Análise e apresentação dos resultados das coletas dos *Honeypots*.

2.2.Nepenthes

Programas de computadores com objetivos maliciosos, ilícitos propositalmente ou não, são conhecidos como *malware* (TECHNET, 2011). Esses programas têm se tornado um problema comum para diversos tipos de corporações, instituições financeiras e até mesmo para usuário doméstico, principalmente devido a sua capacidade de se propagar rapidamente pela rede.

Os sistemas de *Honeypots* permitem conceder o conhecimento necessário para se criar estratégias de defesa contra essas pragas virtuais. Por meio da coleta de *malware* torna-se

possível conhecer suas assinaturas digitais facilitando aos desenvolvedores de ferramentas de segurança da informação o desenvolvimento de uma solução rápida e eficaz para suas aplicações.

O *Nepenthes*, desenvolvido em 2005 por Paul Baecher e Markus Koetter, é um *Honeypot* de baixa interatividade projetado para coleta de informações de *malware*. Sua arquitetura envolve a emulação de serviços de rede que possuem vulnerabilidades conhecidas em alguns sistemas operacionais.

De forma escalável, o *Nepenthes* foi projetado e testado para cobrir grandes faixas de endereços IP, com suporte para requisições de mais de 16000 endereços para uma única máquina física (BAECHER et alii, 2006).

2.2.1. Arquitetura do *Nepenthes*

Projetado para ser modular, o *Nepenthes* possui em seu núcleo operacional a responsabilidade de manipular os dados de entrada e saída dos pacotes dados pela sessão do atacante através da interface de rede e também coordenar as ações dos módulos subsequentes.

Em seu *paper* mais famoso, Baecher et alii (2006) descreve os módulos mais importantes do *Nepenthes*, listados a seguir:

- a) **Módulos de vulnerabilidade (*vulnerability modules*):** responsável pela emulação dos serviços de rede, no qual o atacante irá explorar a vulnerabilidade. É considerado o módulo mais importante da arquitetura do *Nepenthes* e é através desse módulo que o mecanismo proporciona a porta de entrada para o atacante. O objetivo destes módulos é emular apenas as partes necessárias de uma vulnerabilidade para que seja suficiente para capturar as informações necessárias do *software* malicioso.

Conforme sua documentação, o *Nepenthes* atualmente possui 16 módulos de vulnerabilidades disponíveis, emulando 19 portas de serviços TCP abertas.

O quadro 3 descreve alguns dos módulos de vulnerabilidades do *Nepenthes* informados em sua documentação e as referências de notificações de segurança relacionadas a eles.

Porta	Vulnerabilidade	Módulo	Referência
42/TCP	MS04-006	vuln_wins	Vulnerabilidade no WINS pode permitir execução de código remoto
	MS04-045		
80/TCP	MS03-007	vuln_ans1	<i>Buffer</i> não verificado em componente do Windows pode comprometer o <i>host</i> , permitindo a execução de código malicioso por parte do invasor
	MS03-051		<i>Buffer overflow</i> no Microsoft FrontPage Server Extensions poderia permitir execução de código
	MS04-011		Execução de código remoto
135/TCP 1025/TCP	MS03-039	vuln_dcom	<i>Buffer overflow</i> no serviço de RPC pode permitir execução de código malicioso como usuário de sistema
	MS04-012		Execução de código remoto
139/TCP		vuln_netbiosname	Não é uma vulnerabilidade real. Este módulo somente replica um nome de <i>host</i> <i>netbios</i> caso seja solicitado pelo atacante
	MS04-031	vuln_netdde	Vulnerabilidade em <i>NetDDE</i> pode permitir execução de código remoto
443/TCP	MS03-007	vuln_iis	<i>Buffer</i> não verificado em componente do Windows pode comprometer o servidor, permitindo a execução de código malicioso por parte do invasor
	MS03-051		<i>Buffer overflow</i> no Microsoft FrontPage Server Extensions poderia permitir execução de código
	MS04-011		Execução de código remoto
445/TCP	MS04-007	vuln_ans1	Execução de código remoto
	MS04-011	vuln_lsass	Execução de código remoto
	MS04-012	vuln_dcom	Execução de código remoto
	MS03-039		<i>Buffer overflow</i> no serviço de RPCSS pode permitir execução de código malicioso como usuário de sistema

Porta	Vulnerabilidade	Módulo	Referência
1023/TCP 5554/TCP		vuln_sasserftpd	Explora uma vulnerabilidade no <i>Daemon</i> de <i>FTP</i> através do <i>Vírus Sasser</i>
1434/TCP	MS02-039	vuln_mssql	<i>Buffer overflow</i> no serviço de resolução do Microsoft SQL Server 2000 permite execução de código remoto
2103/TCP 2105/TCP 2107/TCP	MS05-017	vuln_msmq	Vulnerabilidade no serviço de fila de mensagens do Windows pode permitir execução de código remoto
2745/TCP		vuln_bagle	Emulação de <i>backdoor</i> relacionado ao <i>Worm</i> conhecido como <i>Bagle</i>
3127/TCP		vuln_mydoom	Emulação de <i>backdoor</i> relacionado ao <i>Worm</i> conhecido como <i>myDoom/Novarg</i>
3140/TCP		vuln_optix	Emulação de <i>backdoor</i> relacionado ao <i>Trojan Horse</i> conhecido como <i>Optix Pro</i>
5000/TCP	MS01-059	vuln_upnp	<i>Buffer</i> não verificado em componente do Windows Universal <i>Plug and Play</i> pode comprometer o <i>host</i> , permitindo a execução de código malicioso por parte do invasor
17300/TCP		vuln_kuang2	Emulação de <i>backdoor</i> relacionado ao <i>Worm</i> conhecido como <i>Kuang2</i>
27347		vuln_sub7	Emulação de <i>backdoor</i> relacionado ao <i>Trojan Horse</i> conhecido como <i>Sub7</i>

Quadro 3 – Estrutura de portas e vulnerabilidades usadas pelo núcleo do *Nepenthes* (NEPENTHES, 2010) (TECHNET/2010).

- b) **Módulos de análise de *Shellcode* (*Shellcode parsing modules*):** são os módulos responsáveis pela análise da carga útil (*payload*) do pacote de rede recebido pela aplicação através do módulo de vulnerabilidade. Estes módulos analisam parte do *shellcode* recebido e extraem a informação do *malware* e de como ele se propaga.

Seu funcionamento básico é decodificar o *shellcode*, que na maioria das vezes é criptografado pelo atacante para tentar enganar o *IDS* que normalmente funciona por meio de processamento de *strings*; depois de decodificado é aplicado uma lógica de detecção para verificar a existência de *links* ou comandos para criação de processos no sistema operacional. O próximo passo

é encaminhar essas informações para o módulo de busca para que seja feito o *download* do código malicioso.

- c) **Módulos de busca (*Fetch modules*):** estes módulos permitem obter o binário ou executável do *malware* a partir do local onde ele fica armazenado, mas isso só é possível através das informações que foram coletadas do módulo de análise do *shellcode*. Para executar a transferência estes módulos possuem suporte aos protocolos de comunicação de transferência de dados, tais como *FTP*, *HTTP*, *TFTP*, *IRC* (nesse caso, *csend* e *creceive*), entre outros específicos que foram desenvolvidos especialmente para alguns tipos de *malware* que possuem protocolos próprios utilizados para sua propagação. Estes módulos, uma vez bem-sucedidos em sua tarefa, repassam os dados para o módulo de submissão.
- d) **Módulos de submissão (*Submission modules*):** a partir da obtenção do binário do código malicioso, é possível, através destes módulos, armazená-lo em um banco de dados para pesquisa, enviá-lo para ferramentas de análises dinâmicas, conhecidas como *Sandbox*, ou encaminhá-lo diretamente para os desenvolvedores de antivírus.
- e) **Módulos de logging (*Logging modules*):** através destes módulos é possível registrar todas as tarefas dos processos executados pelo *Honeypot*, dentre eles podem ser citados a emulação dos serviços, listagem dos binários executados e envio da submissão para o *Sandbox*.

Todos os componentes ora citados são tarefas executadas pelo *framework* que completam um ciclo de informações importantes para se chegar ao conhecimento da assinatura do *malware*. Esse ciclo de informações pode ser visto de forma didática através da Figura 1-2, ilustrada pelos desenvolvedores da aplicação.

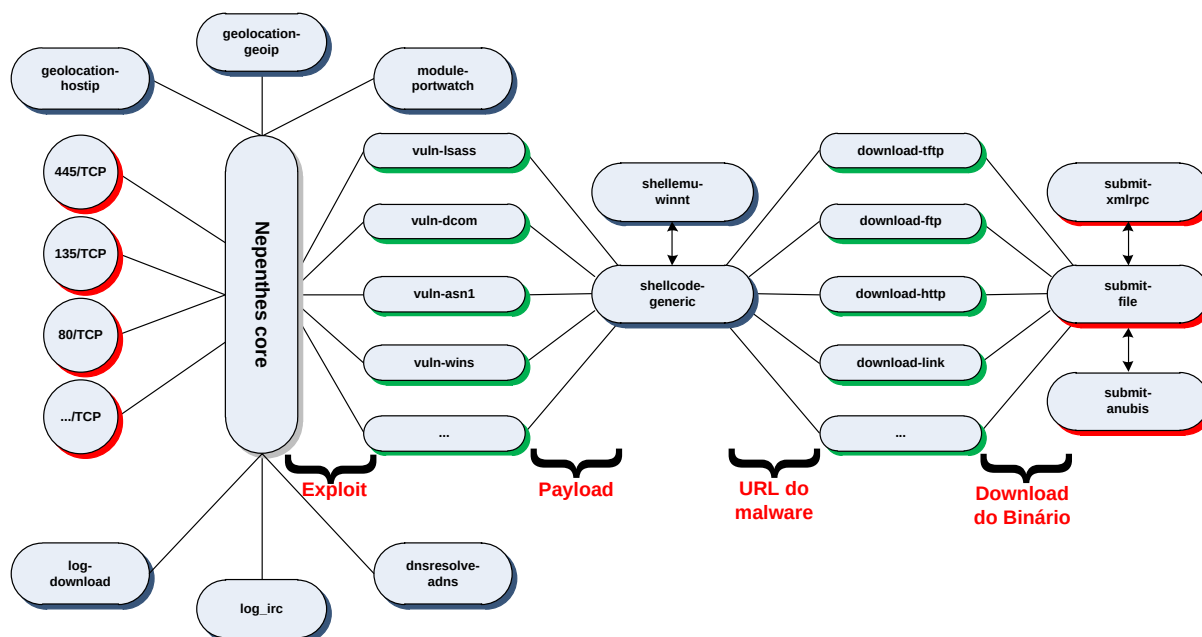


Figura 1-2 – Conceito por trás do núcleo do *Nepenthes* (adaptado de BAECHER et alii, 2006)

2.2.2. Emulação de *Shell*

Faz parte da estrutura e metodologia do *Nepenthes* a simulação de um *Shell* Windows (comando CMD.exe). Apesar de ser uma simulação limitada, é possível que muitos dos comandos do sistema operacional sejam interpretados e até mesmo que haja suporte a execução de arquivos de lote (.bat) (BAECHER et alii, 2006). Essa é uma estratégia inteligente que permite enganar alguns tipos de ataques mais comuns de *malware* que utilizam como base esse método.

Em conjunto com esta técnica, o *Nepenthes* possui um sistema de arquivos simples implementado de forma virtual para cada sessão de *shell* aberta, que possibilita que sejam criados arquivos sob demanda no qual o invasor pode modificá-los e acessá-los normalmente. A eficiência do recurso de *shell* e sistema de arquivos virtuais permite que ao final do processo do ataque o código malicioso seja capturado automaticamente.

2.3.Dionaea

O *Dionaea* é um *Honeypot* de baixa interatividade desenvolvido por Markus Koetter, o mesmo criador do *Nepenthes* e financiado inicialmente pelo “*The Honeynet Project*” (DIONAEA, 2010). Sua primeira versão foi lançada em 2009 e seu desenvolvimento aberto para a comunidade *open source*. Apesar de sua arquitetura ser muito parecida com o *Nepenthes*, este *Honeypot* foi projetado para subjugar os mais novos métodos e técnicas utilizados pelos *malware* atualmente, além de dar suporte ao protocolo *IPv6*, criptografia *TLS* e ao protocolo *SIP* utilizado nas tecnologias *Voice Over IP (VoIP)* (DIONAEA, 2010).

Este *framework* tem como função principal ser o substituto do *Nepenthes*. Sua arquitetura provê a emulação de serviços de redes nos quais o *malware* possa explorar vulnerabilidades mais novas e conhecidas para se obter uma cópia do código malicioso.

Um dos desafios mais complexos desta pesquisa foi coletar informações e documentações sobre este *framework*. Por ser uma aplicação nova na comunidade, existe uma escassez muito grande relacionada à sua documentação, que por fim acabou ficando limitada ao *site* do desenvolvedor e algumas informações disponíveis no site “*The Honeynet Project*”.

2.3.1. Arquitetura do *Dionaea*

Com seu núcleo desenvolvido em linguagem C e seus *plugins* integrados em linguagem *Python* via *Cython* e uma série de outras bibliotecas padrões já conhecidas da comunidade *open source*, sendo elas: *libdev*, *liblcfg*, *libemu*, *libcurl*, *libpcap*, entre outras.

Basicamente seu funcionamento geral vem da execução dos *scripts* escritos em linguagem *Python* que emulam os serviços de rede. O *Dionaea* passa a oferecer em sua arquitetura suporte aos protocolos *TCP*, *UDP* e *TLS* para as versões de *IPv4* e *IPv6*. A facilidade de implementação dos protocolos de rede através da linguagem *Python* permite ajustes fáceis à camada de protocolo. Um exemplo é permitir a utilização de ligações do tipo *non-blocking*, fornecendo suporte à limitação de taxas de conexões para os protocolos *TCP* e *TLS*, se necessário.

Levando em consideração a estrutura modular encontrada no *Nepenthes* e caracterizando as bibliotecas *open source* utilizadas na execução do *framework Diona* da mesma forma, elas são discriminadas da seguinte forma:

- a) **Módulos de vulnerabilidade (*vulnerability modules*):** o principal *engine* dos *plugins* desenvolvidos em formato de *scripts* são interpretados pelo módulo de linguagem *Phyton*. Nesta fase foram implementados os protocolos e vulnerabilidades utilizados pelo *framework*.

Segundo sua documentação (DIONAEA, 2010) o *Diona* apresenta nestes módulos de vulnerabilidades 7 portas de serviços *TCPs* e 02 *UDPs* - Quadro 4 - abertas exploradas através dos seguintes protocolos:

- i. **SMB:** o protocolo *Server Message Block* (SMB), um dos mais conhecidos no mundo relacionado à segurança computacional por ter um dos maiores históricos de registros de vulnerabilidades exploráveis relacionadas na Common Vulnerabilities and Exposures (CVE, 2011), detentora de uma base de dados de protocolos e vulnerabilidades conhecidas. O SMB é um protocolo baseado em compartilhamento de arquivos dentro de uma *Local Area Network* (LAN) ou rede interna, que permite a manipulação de arquivos nas operações de leitura, escrita, criação, deleção e alteração, entre outras suportadas. Este é o principal protocolo oferecido pelo *Diona*. Sua emulação, além de possuir vulnerabilidades para ataques conhecidos, também suporta *upload* de arquivos em um ambiente *shell* operando com compartilhamento *SMB*.
- ii. **HTTP/HTTPS:** apesar de dar suporte às portas 80 e 443 *TCP* não foi implementado nenhum *plug-in* para exploração de vulnerabilidade e utilização dessas portas. O *Diona* apenas recebe as informações de conexão para contabilizar em seus *logs* as tentativas de acesso aos serviços.

- iii. **FTP**: com suporte básico à porta 21 *TCP*, em um ambiente emulado, permite a criação, *upload* e *download* de arquivos; no final do ataque utiliza as informações para captura de *malware*.
- iv. **TFTP**: o *Dionaea* fornece um servidor de *TFTP* na porta 69 *UDP*. Esta camada foi desenvolvida para testar as conexões no protocolo *UDP*, com o intuito de testar e avaliar conexões de ataques automatizados sobre o serviço.
- v. **MSSQL**: em escuta na rede através da porta 1433 no protocolo *TCP*, esta camada implementa o protocolo *TDS* utilizado pelo serviço da aplicação Microsoft SQL Server, que permite ao atacante executar *logins* de acesso para que ele tente executar consultas ao banco de dados. Devido à inexistência de um banco, o sistema deixa de responder à consulta e, conseqüentemente, deixa de haver uma ação adicional por parte do invasor.
- vi. **SIP**: esta camada visa emular o protocolo usado atualmente nas tecnologias de telefonia *VoIP*, com o intuito inicial de apenas registrar as tentativas de conexões. Este módulo também permite a captura de dados binários relacionados ao tráfego de áudio *RTP*. Sua implementação ainda precisa de atenção para ser moldada de forma que possa garantir algum tipo de captura de dados que seja de real valor para a comunidade.

Porta	Vulnerabilidade	Módulo	Referência
21/TCP		<i>FTP</i>	Permite acesso anônimo, com suporte a criação, <i>download</i> e <i>upload</i> de arquivos
42/TCP			Sem módulo de vulnerabilidade
80/TCP 443/TCP	-	<i>HTTP/HTTPS</i>	Sem módulo de vulnerabilidade
135/TCP 445/TCP	MS03-026	<i>SMB</i>	<i>Buffer overflow</i> no serviço de RPC pode permitir execução de código malicioso como usuário de sistema
	MS04-011		Execução de código remoto
	MS04-012		Execução de código remoto
	MS05-017		Vulnerabilidade no serviço de fila de mensagens do Windows pode permitir execução de código remoto
	MS07-065		Vulnerabilidade no cliente de serviço para <i>Netware</i> pode permitir execução de código remoto
	MS06-066		Vulnerabilidade no componente do Windows <i>Plug and Play</i> pode permitir a execução de código malicioso e elevação de privilégios para o invasor
	MS05-039		Vulnerabilidade no serviço de Servidor pode permitir execução de código remoto
	MS08-067		
1433/TCP		<i>MSSQL</i>	Sem módulo de vulnerabilidade
69/UDP		<i>TFTP</i>	Sem módulo de vulnerabilidade
5060/UDP		<i>SIP</i>	Sem módulo de vulnerabilidade

Quadro 4 – Estrutura de portas e vulnerabilidades usada pelo núcleo do *Dionaea* (DIONAEA, 2010) (TECHNET/2010).

- b) **Módulos de análise de *Shellcode* (*Shellcode parsing modules*):** a partir destes módulos é utilizada a biblioteca *libemu*, escrita em linguagem C. Essa biblioteca oferece emulação de instruções de CPU no padrão x86 com suporte a API do Windows em 32 bits (win32), além de permitir a detecção, execução e identificação do perfil de comportamento de *shellcodes* usando o padrão *GetPC* Heurística.

- c) **Módulos de busca (*Fetch modules*):** com as informações fornecidas pelo módulo de *shellcode*, o *Dionaea* faz uso das capacidades da biblioteca *libcurl* para fazer o *download* do código malicioso para sua biblioteca local, utilizando como protocolo principal o *HTTP*. Caso o *download* só possa ser efetuado através dos protocolos *FTP* e *TFTP*, o *download* do código binário será efetuado através da implementação dos *scripts* desenvolvidos em linguagem *Python* (*ftp.py* e *tftp.py*) que fazem parte do *framework*.
- d) **Módulos de submissão (*Submission modules*):** assim como utilizado no *Nepenthes*, o *Dionaea* permite o envio do *malware* para ferramentas de análise dinâmicas, os *Sandboxes*, através dos protocolos *HTTP* e *FTP* que fazem parte do *framework*.
- e) **Módulos de logging (*Logging modules*):** o registro das tarefas executadas pelo *Honeypot* é armazenado em um banco de dados conhecido como *SQLite*. O mais interessante destes módulos é poder contar com o registro de todas as tarefas executadas pelo *framework*, no formato superior a de um texto comum mostrado por um *log* no formato de texto. Além disso, o *Dionaea* permite gravar as ações com um nível de detalhamento muito alto, podendo ser recuperado no formato que o administrador escolher.

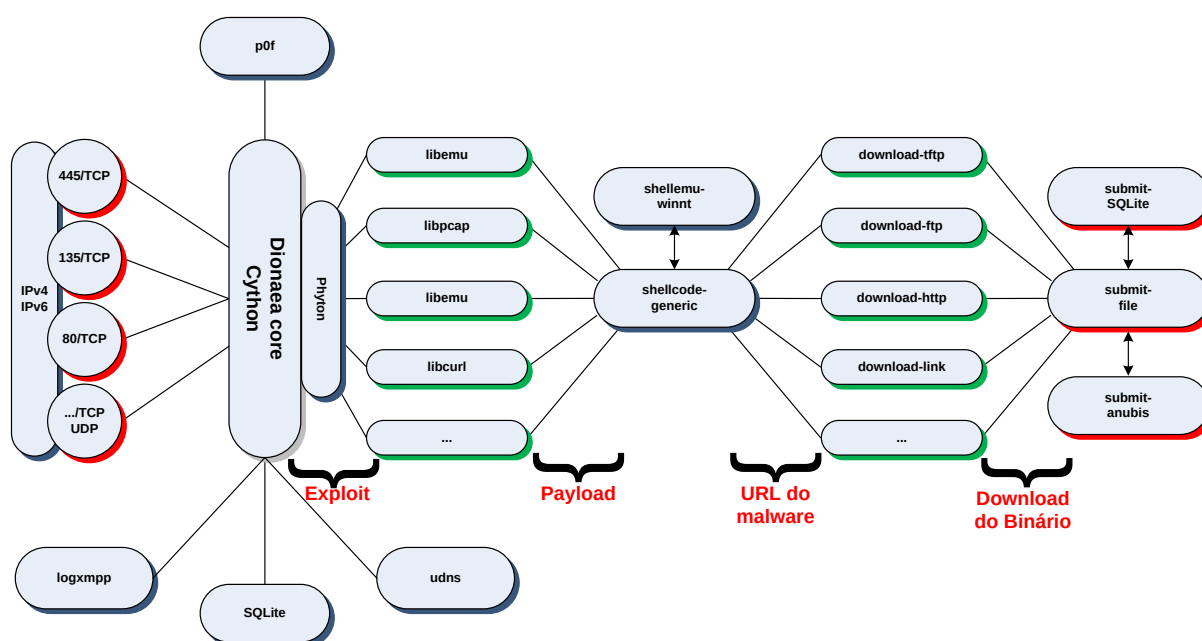


Figura 2-2 – Conceito por trás do núcleo do Dionaea
(Elaborada pelo autor)

2.4.Hardening

Como citado no capítulo anterior, para um *Honeypot* ser bem-sucedido em suas atividades e objetivos é necessário que sua implantação seja bem planejada. Isso inclui principalmente a preocupação relacionada com os aspectos de segurança, seja ela física ou virtual, diante das ameaças reais existentes para que o sistema não seja comprometido e tomado pelo invasor para ser usado como ferramenta em ataques de outros *hosts*.

A metodologia principal utilizada na segurança dos sistemas operacionais usados nesta pesquisa é conhecida como *Hardening*, que constitui no processo de fortalecimento e blindagem do sistema operacional com foco no mapeamento das ameaças, mitigação de riscos e execução de atividades corretivas. Segundo Melo et alii (2006), essas ações caracterizam as medidas necessárias para proteger o sistema operacional de riscos reais que podem comprometer o sistema.

Os tipos de ações e atividades que podem ser executadas quando falamos de *Hardening* são muitos, separados e caracterizados por processos no sistema operacional. Este tópico explica cada uma das ações que foram executadas no ambiente experimental criado para instalação dos *Honeypots*.

Os controles implementados tiveram como base, em sua maioria, controles sugeridos da norma ABNT NBR ISO 27001/2006, e alguns implementados por sugestões encontradas na literatura de boas práticas de *Hardening* (MELO et alii, 2006), e seu embasamento no princípio do menor privilégio. De acordo com SANS (2002 apud SALTZER, 1975):

“cada programa e cada usuário do sistema deve operar usando o menor conjunto de privilégios necessários para completar uma operação.”

Os sistemas operacionais utilizados no ambiente experimental foram instalados no padrão POSIX (FREEBSD/UBUNTU) devido à compatibilidade na instalação dos *Honeypots* e na padronização quanto à aplicação do *Hardening*.

2.4.1. Acesso remoto

Para acesso remoto aos recursos do sistema operacional foi necessário a utilização de uma ferramenta apropriada que garanta segurança na conectividade, para o acompanhamento das atividades e processos do *Honeypot*.

Por se tratarem de sistemas operacionais padrão POSIX, a opção foi a utilização do *daemon* de rede *SSHD* utilizando o conceito de chave privada com criptografia de 1024 bits para realização de conexão remota utilizando um usuário normal sem privilégios administrativos. Depois de estabelecida a conexão em um ambiente seguro é feita a alteração para usuário *root* através do comando *su*. Também foi efetuada a alteração de acesso à porta padrão 22/TCP para 17400/TCP para desvio da atenção dos *scanners* de rede (MELO et alii, 2006) e limitado acesso à porta do *daemon* somente através de endereços IP pré-determinados.

2.4.2. Sistema de arquivos

A preocupação relacionada ao sistema de arquivos foi quanto à mitigação do risco de permissão, no qual o invasor consegue executar comandos como usuário de sistema com privilégios administrativos.

Quando falamos de sistema de arquivos nos sistemas operacionais padrão POSIX um invasor poderia se aproveitar do recurso de *set user id (Suid Bit)*, o qual permite que um programa seja executado com as permissões de usuário dono do arquivo e não com as permissões de quem o invocou. Desta forma, ele procura arquivos utilizados pelo sistema operacional como, por exemplo, a execução de um *shell* como o *bash* (MELO et alii, 2006).

Esse problema foi solucionado a partir da execução dos comandos abaixo, que permitiram a remoção dos atributos *SUID* e *GUID* dos arquivos com exceção do comando *su*.

```
“find /-02000 \! -name “su*” -print -exec chmod -s {} \;”
```

```
“find /-04000 \! -name “su*” -print -exec chmod -s {} \;”
```

A segurança do sistema de particionamento de disco também é um fator relevante e eficiente para um potencial ataque. Segundo Melo et alii (2006), quando um sistema operacional padrão POSIX é instalado, não é implementado nenhum padrão de segurança ao sistema de arquivos; as partições ficam com permissão para execução de arquivos binários ou *scripts* executáveis, o que possibilitaria ao atacante executar qualquer tipo de aplicação dentro do sistema ou inserida por ele.

Um exemplo tático para mitigação desse risco é a configuração dos atributos de segurança *nosuid* e *noexec* dentro do arquivo que executa a montagem automática das partições do sistema.

- a) ***nosuid***: com este atributo configurado na montagem da partição, os arquivos mesmos configurados com os atributos *suid* e *guid* ativados não vai possibilitar o acesso ao nível de *root* quando executado.
- b) ***noexec***: com este atributo configurado na montagem da partição, o sistema impossibilita a execução de qualquer tipo de arquivo binário dentro dela.

Tabela 1 – Exemplo de aplicação dos atributos *nosuid* e *noexec* (MELO et alii, 2006)

Ponto de Montagem	<i>nosuid</i>	<i>noexec</i>
<i>/boot</i>	X	-
<i>/</i>	-	-
<i>/home</i>	X	X
<i>/usr</i>	X	-
<i>/tmp</i>	X	X
<i>/var</i>	X	X
<i>/var/log</i>	X	X

#vi /etc/fstab					
<i>/dev/hda1</i>	<i>/boot</i>	<i>ext3</i>	<i>defaults,nosuid</i>	<i>0</i>	<i>2</i>
<i>/dev/hda4</i>	<i>/home</i>	<i>ext3</i>	<i>defaults,nosuid,noexec</i>	<i>0</i>	<i>2</i>

Quadro 5 – Ilustração do uso de *nosuid* e *noexec* dentro do arquivo *fstab* (MELO et alii, 2006).

2.4.3. Kernel

O *Kernel* é o núcleo do sistema operacional, o programa mais importante do sistema. Ele é carregado diretamente na memória *RAM* (*Random Access Memory*) quando o sistema é inicializado, e possui muitos dos processos mais críticos que fazem o sistema funcionar. Explicando melhor o seu funcionamento, o *Kernel* age como um mediador entre os componentes físicos (*hardware*) e os processos que estão em execução, impedindo que eles acessem diretamente o *hardware*.

Neste tópico a seguir serão citadas as táticas comuns encontradas nas literaturas que foram utilizadas para blindagem dos sistemas operacionais utilizados no ambiente experimental:

- a) **Compilação do Kernel:** um dos fatores mais comuns, a compilação do *Kernel* do sistema operacional consiste em remover os módulos e características que não foram utilizados pelo sistema operacional. Isso além de reduzir o espaço que o *Kernel* utiliza na memória evita que o invasor tenha acesso ao módulo que possa ter algum tipo de vulnerabilidade a ser explorada.
- b) **Nível de segurança do Kernel:** o *FreeBSD* permite alterar o nível em que seu *Kernel* é executado. Cada nível de execução tem fatores de proteções diferentes. Por uma questão de padrão, seu modo vem configurado sem nenhum nível de segurança (nível - 1). Os níveis de segurança são definidos da seguinte forma:
 - i. **Modo permanentemente inseguro (-1):** é o valor padrão configurado ao instalar o sistema operacional. Neste nível não existe qualquer implementação de segurança em nível de *Kernel*.
 - ii. **Modo inseguro (0):** todos os dispositivos podem ser lidos ou escritos sujeitos às suas devidas permissões.
 - iii. **Modo Seguro (1):** não é possível carregar módulos do *Kernel* a não ser que ele seja recompilado. Nenhum programa poderá escrever diretamente na memória do sistema; discos que foram montados não

poderão ser gravados diretamente, não sendo possível formatar partições nesses discos.

- iv. **Modo altamente seguro (2):** além da segurança do nível anterior, há a impossibilidade de escrever diretamente nos sistemas de arquivos, sejam eles montados ou desmontados; impossibilidade de alterar a estrutura do sistema de arquivos, redefinir ou modificar opções de montagem e de formatar a partição usando *newfs* quando o sistema estiver em modo multiusuário.
- v. **Modo de rede segura (3):** além da segurança imposta aos níveis superiores, este nível impossibilita alterar as definições de regras de *firewall* utilizando as aplicações *IPFW*, *PF* ou *PFCTL*, além de proibir modificações nos sistemas de enfileiramentos, como o *ALTQ* ou *DUMMYNET* usados para *QoS (Quality of Service)*.

No servidor que foi executada a instalação do sistema operacional *FreeBSD* foi utilizado o nível 3, modo de rede segura. Para essa configuração foram adicionadas as duas linhas de comando abaixo dentro do arquivo “*/etc/rc.conf*”, conforme indicação do quadro a seguir:

#vi /etc/rc.conf
<pre># Ativação de nível de segurança do Kernel kern_secure_level_enable="YES" kern_secure_level="3"</pre>

Quadro 6 – Ilustração da implantação do nível de segurança do *Kernel (FREEBSD, 2010)*.

2.4.4. Atualizações e *patches* de segurança

Outro fator fundamental é manter o sistema operacional, seus componentes e pacotes de aplicações instalados devidamente atualizados. A maioria das distribuições dos sistemas operacionais possui um sistema automatizado que permite verificar se ele está desatualizado ou se é passível de falha e vulnerabilidade conhecida e divulgada por grupos de segurança.

Esses grupos lançam relatórios de segurança conhecidos como *Security Advisories*, alertando a respeito de possíveis falhas sobre aplicações específicas.

Para verificação e atualização do sistema operacional, foram utilizados semanalmente para cada um dos recursos discriminados abaixo:

- a) **No *FreeBSD*** - Utilização das ferramentas executadas através do *shell* em linha de comando:
 - i. *portaudit* - esta ferramenta permite verificar em uma base *on-line* se existem vulnerabilidades e suas devidas referências nos pacotes de aplicativos instalados no sistema operacional.
 - ii. *portsnap* - esta ferramenta possibilita a atualização das versões de pacotes dos aplicativos que foram e podem ser instalados no sistema operacional. Somente após ter a base atualizada é possível reinstalar ou recompilar as aplicações utilizadas no sistema, que pode ser feita via *PORTS* ou pelo comando *portupgrade*.
 - iii. *cvsup* – utilizando um arquivo de configuração-base, esta ferramenta permite fazer o *download* das atualizações e *patches* de segurança mais recentes do sistema operacional.
- b) **No *Ubuntu*** - Utilização da ferramenta executada através do *shell* em linha de comando:
 - i. *apt-get* – a partir das opções *install*, *update* e *upgrade* inclusas no comando é possível verificar, instalar ou atualizar aplicações e/ou atualizações de segurança disponíveis para este sistema operacional;

2.4.5. Hardenings diversos

A seguir será comentada uma miscelânea de procedimentos adicionais de *Hardening* que foram utilizados como reforço na montagem do ambiente experimental.

- a) **Forçar a desativação do *PORTMAPPER*:** O *Portmapper* é um *daemon* de porta dinâmica para serviços *RPC*, como o *NIS* e o *NFS*. Possui mecanismos de autenticação fraca e delega um enorme número de portas para os serviços que controla. Por não ser necessário no ambiente experimental, foi forçada a desativação deste serviço usando:
 - i. **No *FreeBSD*:** configuração no arquivo *“/etc/rc.conf”* com a inclusão da linha *“portmap_enable=NO”*.
 - ii. **No *Ubuntu*:** utilizando o comando *“sudo update-rc.d portmap disable”*.
- b) **Forçar a desativação do *SENDMAIL*:** em alguns sistemas operacionais, o *daemon* *Sendmail* vem configurado por padrão, deixando habilitado o serviço de entregas de e-mail para o sistema operacional, que pode ser explorado por um invasor:
 - i. **No *FreeBSD*:** configuração no arquivo *“/etc/rc.conf”* com a inclusão das linhas *“sendmail_enable=NO”*, *“sendmail_submit_enable=NO”*, *“sendmail_outbound_enable=NO”* e *“sendmail_msp_queue_enable=NO”*.
 - ii. **No *Ubuntu*:** utilizando o comando *“sudo update-rc.d sendmail disable”*.

2.5. Ambiente Experimental

Neste tópico serão apresentados os ambientes computacionais que foram montados para execução, coleta de dados e avaliação de cada um dos *Honeypots* configurados: o *Nepenthes* e o *Dionaea*.

A opção pela utilização e análise dessas ferramentas foi dada após a pesquisa inicial ser inviabilizada e desconsiderada. O objetivo principal da pesquisa era a avaliação da difusão de *malware* em sistemas de banda larga através das tecnologias *ADSL*, *CABLE* e *3G* utilizando o *Honeypot Nepenthes*. Após quase três meses de monitoramento, a pesquisa tornou-se inviável para avaliação devido à utilização de filtros de portas que eram aplicados pelas operadoras que forneciam o *link* e que não permitiam acesso externo às portas utilizadas pela aplicação, exibido no Quadro 2 deste documento.

Logo após a inviabilidade técnica do primeiro cenário, foi montado um segundo cenário somente para experimentação e avaliação. Nele foi instalado apenas um sensor com a aplicação *Dionaea* no *link ADSL* para verificar o seu comportamento, e como já era esperado, mais uma vez o sistema não pôde mostrar sua eficiência com os filtros das operadoras aplicados.

De qualquer forma, o tempo gasto nesses dois primeiros cenários não foi em vão. Além de permitir o conhecimento das duas ferramentas, é de suma importância afirmar que a utilização dos sistemas de banda larga relacionados aos produtos testados das operadoras Speedy Telefônica/SP (*ADSL*), Net Virtua/SP (*Cable Modem*) e Vivo/SP (*3G*) com a aplicação de seus filtros padrões em cima das portas de serviços de rede conhecidas por suas vulnerabilidades exploráveis na comunidade *underground* no mundo computacional em que vivemos hoje, nos permite ter uma segurança adicional. Isso não quer dizer que o sistema é 100% seguro e que não é necessária a instalação de sistemas de proteção, mas já mostra certa conscientização por parte das grandes operadoras quanto à questão de segurança computacional.

Na terceira fase de montagem do ambiente experimental o empenho pela busca ao conhecimento e adaptação tecnológica aumentou; optou-se, então, por uma mudança estratégica, mas ainda correlacionada com o tema original. Nessa fase de planejamento foram levantados quais seriam os recursos computacionais disponíveis a fim de direcionar a pesquisa para um caminho certo.

Com a ajuda imprescindível da gerência do Departamento de Tecnologia da empresa GENPRO Engenharia, que gentilmente cedeu três endereços IP válidos de dois *links* dedicados, e com a soma do conhecimento dos estudos já adquiridos sobre as ferramentas de *Honeypots* foi que a pesquisa se moldou ao seu cenário final: a montagem de um ambiente

experimental, utilizando um *link* de Internet dedicado sem qualquer tipo de filtro dado pela operadora, no qual foram colocados sensores, sendo eles: 1 *Nepenthes* e 1 *Dionaea*, que foram utilizados para o estudo da análise da difusão de *malware* comparando a eficiência entre os dois *frameworks*.

2.6. Descrição do ambiente experimental

Nessa fase foram alocadas três máquinas físicas de mesma configuração dedicadas exclusivamente à execução do experimento, sendo duas delas para instalação dos *Honeypots* e uma para coleta diária dos *logs* e dados obtidos pelos *frameworks*. Os *Honeypots* utilizados não necessitaram de equipamentos de última geração em termos de processamento e memória. Usando esse argumento, foram utilizados equipamentos que não são mais usados no dia-a-dia para produção.

Os equipamentos utilizados para os *Honeypots* têm como sua configuração base:

- Processador Intel Celeron 1.7 GHz (com arquitetura x86);
- 1 GB de memória RAM;
- 40 GB de disco rígido.

Para o equipamento utilizado na gerência e coleta dos *logs* e dados obtidos pelos *frameworks* foi usada a mesma configuração, salvo o disco rígido, que nesse caso é de 160 GB.

Para cada um dos *frameworks* instalados foi utilizado um sistema operacional, e mesmo sendo padrão *POSIX*, cada um tem sua particularidade.

Para instalação do *Nepenthes* foi utilizado *FreeBSD* 8.1 versão *STABLE*. Este sistema operacional foi escolhido devido ao conhecimento adquirido pelo autor sobre ele ao longo do tempo e também por causa da compatibilidade do *framework*, por este estar disponível no leque de ferramentas para instalação via *PORTS* do sistema operacional, não necessitando a verificação ou instalação de qualquer dependência sobre o sistema.

Para instalação do *Dionaea* foi utilizado o sistema operacional *Ubuntu Server* 10.10 (última versão do sistema até a presente data). Esse sistema operacional foi selecionado porque a documentação do *framework* apresenta passos simples e necessários para instalação de seu

core (núcleo) e suas dependências, bem como sua compatibilidade total nesse sistema operacional.

Para este experimento, foram tomados alguns cuidados quanto à utilização de data e hora para que não houvesse erros na geração dos *logs* e eventos do sistema. Para isso, os relógios dos equipamentos foram sincronizados com o serviço de *NTP* através do *host ntp1.pucpr.br*.

A topologia de rede criada para implantação do ambiente foi a mesma utilizada em várias literaturas, como em Addison e Wesley (2002) e em Marcelo e Pitanga (2003), os quais descrevem uma *Honeynet*. A figura a seguir ilustra o formato dessa topologia, adaptada pelo autor para evolução do ambiente experimental:

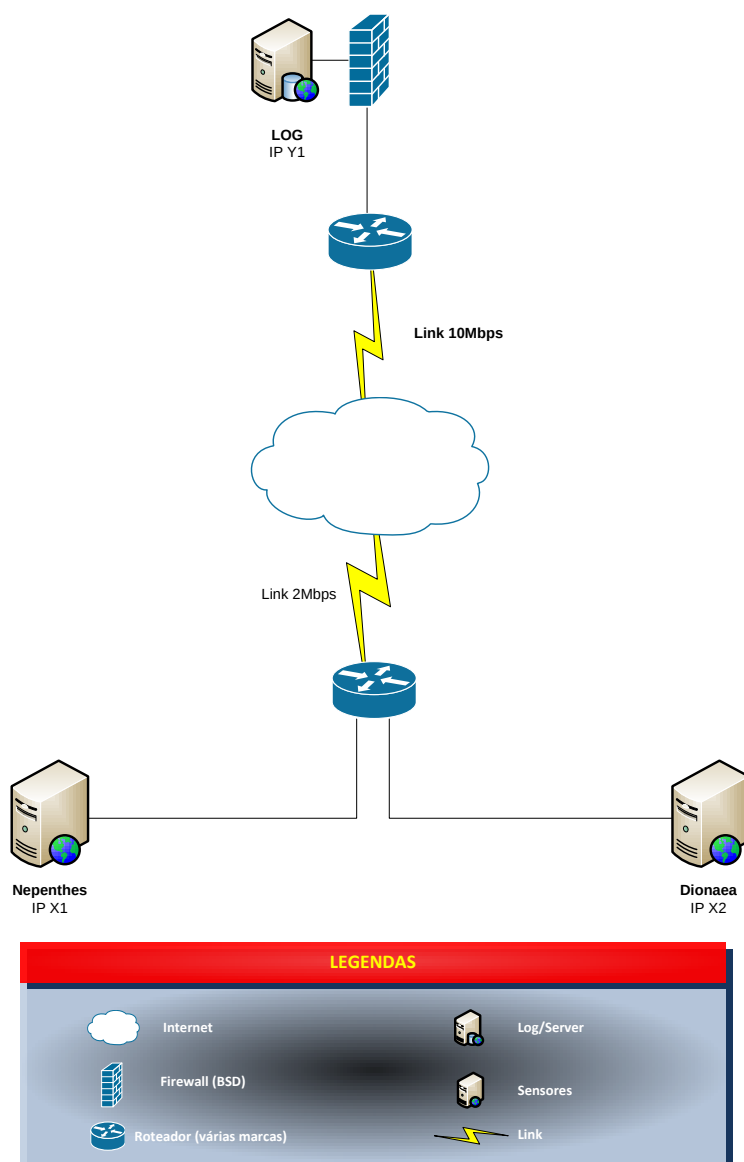


Figura 3-2 – Ilustração da topologia proposta
(Elaborada pelo autor)

Como já informado, foram disponibilizados três endereços de rede IP públicos, dentre eles dois alocados de um *link* de 2 Mbps dedicado utilizados para os *Honeypots* e um IP de um *link* de 10Mbps utilizado no servidor que fará a guarda dos *logs*. Para fins de privacidade e anonimato dos equipamentos, esses endereços não serão divulgados neste documento e serão representados como *IPX1*, *IPX2* e *IPY1*, conforme indicado na ilustração Figura 3-2.

A instalação dos sistemas operacionais informados foi feita de forma cuidadosa e foi aplicada a metodologia de *Hardening* previamente detalhada neste documento.

Tanto na instalação do *Nepenthes* como na instalação do *Dionaea* foram utilizados os arquivos de configuração padrão usados para coleta dos *malware*, sendo incluso na configuração apenas o *link* para *upload* no *Sandbox Anubis*, sem nenhuma configuração ou uso de adicional.

Uma vez que a configuração inicial foi montada, havia a necessidade de fazer um *backup* diário dos *logs* e dados coletados de cada equipamento de forma segura, a fim de garantir sua integridade. A solução proposta foi o desenvolvimento de um *script*, que ao ser executado no final do dia compactava e gravava as informações mais relevantes em um único arquivo no formato *nomedoframework.aaammdd.tar.gz*, em que o *nomedoframework* poderia ser *nepenthes* ou *dionaea* e *aaammdd* representando o ano, mês e dia de geração e coleta do arquivo. O código fonte do *script* pode ser consultado no Apêndice A deste documento.

O próximo passo era efetuar a transferência desse *backup* de forma segura para ser armazenado no servidor de *logs*. A solução encontrada foi fazer a transferência dos dados executando um *script* a partir do servidor de *logs*, utilizando os recursos do protocolo *SCP* e usando chave pública/privada de 4096 bits para autenticação sem intervenção de senha.

#Backup dos Logs Dionaea

```
scp -P 17400 sensorbackup@ipdoservidor:dionaea.'$data'.tar.gz
```

Quadro 7 – Exemplo do comando usado para transferência segura dos *logs* (FREEBSD, 2010).

O *firewall* dos sensores foi configurado para bloquear apenas a porta usada no SSH a 17400/TCP, permitindo acesso a esta porta somente para o servidor de *logs* e à rede definida para acesso administrativo. Qualquer outro tipo de acesso foi configurado como “*liberado*” para não afetar a eficiência do sensor.

#Firewall FreeBSD

```
00300 allow log logamount 100 ip from 10.10.5.0/28 to me dst-port 17400
00310 deny log logamount 100 ip from any to me dst-port 17400
01000 check-state
65500 allow log logamount 100 ip from any to any keep-state
```

Quadro 8 – Exemplo do uso do *firewall* no sensor *Nepenthes* (FREEBSD, 2010).

Em especial, no servidor onde o *framework Nepenthes* foi configurado, foi habilitado o *log* de conteúdo de pacotes no formato *pcap* para estudar os ataques em ferramentas como o *Wireshark*. Os *logs* foram gerados a partir da aplicação *TCPDUMP* como mostra o quadro a seguir:

#Log no formato pcap iniciado a partir do arquivo /etc/rc.local

```
/usr/sbin/tcpdump -s 1500 -w /var/log/ipfw/ipfw.pcap &
```

Quadro 9 – Exemplo do uso da ferramenta *tcpdump* para gerar *log* de conteúdo

O *Dionaea*, por padrão, gera *logs* de conteúdo de forma automática utilizando o módulo *pcap* incluso em sua estrutura.

Após a montagem e testes do ambiente experimental desse último cenário, o sistema ficou no ar desde o dia 12 de janeiro de 2011 até o dia 27 de janeiro de 2011. No período de 15 dias foram coletados cerca de 10.577% *malware* a mais em relação aos três meses de monitoramento feitos no primeiro cenário.

Capítulo 3

3. ANÁLISE DOS DADOS

As análises, estatísticas e resultados apresentados nesta pesquisa foram extraídos a partir das informações dos *logs* gerados pelo sistema, arquivos binários coletados e informações dadas pelas submissões encaminhadas ao *Sandbox Anubis*.

Dentre as análises efetuadas, foram considerados os aspectos mais importantes:

- As ferramentas usadas na análise dos dados
- Catalogação dos tipos de *malware* coletados
- Os *malware* mais coletados
- Estatísticas relacionadas aos países nos quais se originaram o ataque
- Os endereços IP de origem que mais requisitaram conexões
- As portas mais exploradas pelos invasores
- Estatística relativa à quantidade diária de códigos maliciosos coletados

3.1.Ferramentas utilizadas para análise dos dados

Para se ter uma visão melhor de como foi efetuada a análise, esta sessão tem como finalidade principal apresentar uma visão geral das principais ferramentas utilizadas para leitura e interpretação dos dados coletados pelos sensores.

- a) ***Sandbox Anubis***: o *Sandbox Anubis* foi desenvolvido pelo Laboratório de Sistemas de Segurança Internacional e patrocinado pela Secure Business Áustria. Os *Sandboxes* são recursos computacionais criados com o intuito de analisar o comportamento dos arquivos executáveis com foco em especial na análise de *malware*. Este recurso foi usado pelos *Honeypots* em sua fase de submissão dos programas maliciosos. Após a submissão do *malware*, o *Anubis* analisa e gera um relatório que contém informações extremamente importantes sobre o funcionamento geral do código malicioso, sobre os seus riscos, e principalmente se sua assinatura é conhecida pelos fabricantes de antivírus. Seu funcionamento é baseado no conhecimento da assinatura *md5* do *malware*, ou seja, uma vez que o *hash* do código malicioso é conhecido em sua base de dados, a aplicação encaminha automaticamente o *link* de um relatório existente de

sua base; se o *hash* não for conhecido, ele executa a análise em um ambiente emulado e observa sua execução, gerando um novo relatório para sua base de dados e encaminhando o *link* do resultado para o usuário. As informações desse relatório podem ser vistas em uma amostra disponível no Anexo A deste documento.

- b) **Vírus Total:** assim como o *Anubis*, o site www.virustotal.com é um *Sandbox* que permite a análise dos *malware* (na pesquisa ele não foi usado para submissão dos *malware*). Nesse caso, foi utilizado apenas para consulta de sua base de dados para verificar a assinatura dos códigos maliciosos através de seu *hash md5*. Se o *hash* for conhecido, ele informa quais são os nomes comuns dos *malware* dados pelas ferramentas de antivírus nas quais eles foram analisados e testados.

A opção pela utilização desta ferramenta foi considerada porque a pesquisa na base de dados deste site, através do *hash md5*, trouxe informações importantes relacionadas ao nome do *malware* coletado divulgado pelas ferramentas de antivírus mais conhecidas no mercado. Fator que se tornou um facilitador para o aprofundamento da pesquisa na busca de informações mais detalhadas sobre o código malicioso.

- c) **Máquina Virtual com Windows XP e TrendMicro Titanium Maximum Security:** esta máquina virtual foi criada com o intuito de verificar as assinaturas dos *malware*, principalmente as que foram identificadas como desconhecidas pelo *Anubis* ou que não constam no banco de dados do *Vírus Total*. Esta VM serviu também para confirmar o nome comum do *malware* identificado pelo antivírus da TrendMicro.
- d) **Enciclopédia de ameaças Trend Micro:** esta biblioteca foi utilizada para pesquisar as principais características dos *malware* “Top 5” identificados pelas ferramentas *Nepenthes* e *Dionaea*.

Buscou-se utilizar essa enciclopédia porque sua base, diferente de outras pesquisadas (MCAFEE, 2011)(SOPHOS, 2011), é mais completa em relação ao detalhamento dos *malware*, neste detalhamento inclui-se tipo do *malware*, potencial de ataque, vulnerabilidade explorada, data de sua primeira aparição e/ou coleta e em diversos casos um detalhamento técnico sobre sua execução e ações no sistema operacional.

- e) **Biblioteca *libpcap***: esta biblioteca é um monitor de conexão e foi utilizada para coletar os pacotes que tiveram suas conexões rejeitadas. No *Dionaea* esta biblioteca é utilizada como padrão e os resultados registrados no *SQLite*. Para o *Nepenthes*, foi habilitado o recurso *log_in_vain* no sistema operacional *FreeBSD* e os resultados registrados no *log* do sistema operacional.
- f) **Script *readlogsqtree.py***: este *script* foi utilizado para executar consulta no banco de dados *SQLite* utilizado pelo *Dionaea*. Escrito em linguagem *Python*, este *script* permite extrair facilmente informações sobre os ataques, vulnerabilidades exploradas, tempo de ataque, informações sobre o *download* do *malware*, etc. A Figura 1-3 exibe uma pequena amostra das informações que este *script* pode extrair:

```

2010-11-23 03:00:38
connection 29181 smbd tcp accept 192.168.15.101:445 <- 201.92.227.56:3875 (29181 None)
2010-11-23 03:00:38
connection 29182 smbd tcp accept 192.168.15.101:445 <- 201.92.227.56:3893 (29182 None)
dcerpc bind: uuid '4b324fc8-1670-01d3-1278-5a47bf6ee188' (SRVSVC) transfersyntax 8a885d04-1ceb-11c9-9fe8-08002b104860
dcerpc request: uuid '4b324fc8-1670-01d3-1278-5a47bf6ee188' (SRVSVC) opnum 32 (NetPathCompare (MS08-67))
dcerpc request: uuid '4b324fc8-1670-01d3-1278-5a47bf6ee188' (SRVSVC) opnum 31 (NetPathCanonicalize (MS08-67))
profile: [{'return': '0x7df20000', 'args': ['urlmon'], 'call': 'LoadLibraryA'}, {'return': '0', 'args': ['', 'http://201.92.227.56:6782/ljjak', 'x.', '0', '0'], 'call': 'URLDownloadToFile'}, {'return': '0x00000000', 'args': ['x.'], 'call': 'LoadLibraryA'}, {'return': '0', 'args': ['0'], 'call': 'ExitThread'}]
offer: http://201.92.227.56:6782/ljjak
download: 5d2531b911c3aa41cad99a0clac3146d http://201.92.227.56:6782/ljjak
names
2010-11-23 03:29:05
connection 29183 pcap tcp reject 192.168.15.101:35467 <- 184.72.18.55:57478 (29183 None)
2010-11-23 03:29:05

```

Figura 1-3 – Exemplo de consulta ao *SQLite* do *Dionaea* usando o *script readlogsqtree.py*.

- g) **Maxmind.com**: ferramenta utilizada através de consulta em *site* da *web*, que permitiu que fossem identificados os países dos endereços IP de origem dos ataques de cada *malware*.

3.2. Estatísticas dos tipos de *malware* coletados

A primeira análise realizada foi focada na tabulação dos dados para catalogação geral dos códigos maliciosos coletados por ambos os sensores. Foi verificada individualmente cada uma das assinaturas (dados disponíveis de forma resumida no Apêndice B). Este catálogo permitiu que fossem visualizados os dados relacionados a:

- **categoria do *malware*** – abordagem de verificação para conhecer em qual sistema operacional o código malicioso pode ser executado;

- **tipo de *malware*** – verificação da classificação no qual o *malware* se encaixa, *worm*, *vírus*, *trojan*, *spyware*, etc;
- **tipo de impacto relacionado à privacidade** – verificação através dos relatórios do Sandbox Anúbis e informações relatadas na biblioteca de ameaças da TrendMicro (2011) para conhecimento do grau de impacto causado pelo *malware* relacionado à privacidade dos dados do equipamento infectado, ou seja, verificação das ações do *malware* quanto à permissão de acesso remoto não autorizado no equipamento;
- **tipo de impacto relacionado à produtividade** – verificação através dos relatórios do Sandbox Anúbis e informações relatadas na biblioteca de ameaças da TrendMicro (2011) para conhecimento do grau de impacto causado pelo *malware* relacionado à produtividade, ou seja, se o equipamento ocupa área de memória, criação de processos e recursos no sistema operacional, entre outros;
- **tipo de impacto relacionado à integridade do sistema** – verificação através dos relatórios do *Sandbox Anúbis* e informações relatadas na biblioteca de ameaças da TrendMicro (2011) para conhecimento do grau de impacto causado pelo *malware* relacionado à integridade dos dados do sistema operacional, ou seja, verificar quais são os arquivos que foram criados ou alterados pelo código malicioso;
- **risco geral causado pelo *malware*** – visão geral do risco e ações geradas pelo *malware*, considerando todos os aspectos anteriores e informações adicionais reportadas no relatório do *Sandbox Anúbis*.

3.3.O primeiro *malware*

Por se tratar de uma pesquisa científica, não poderíamos deixar de mencionar o primeiro *malware* coletado pelo sistema. Essa coleta foi realizada no primeiro cenário apresentado neste documento a partir do *framework Nepenthes*, utilizando como *link* principal o *ADSL* da operadora Telefônica/SP.

De posse da assinatura do código malicioso, o primeiro passo foi submeter à análise sua assinatura ao *Sandbox Anubis*. Os resultados apresentados no Quadro 10 a seguir é um resumo do relatório gerado pelo *Sandbox* em conjunto com uma pesquisa adicional, mostrando um detalhamento extra sobre o *malware*:

Worm_Doomjuice.b – TrendMicro / Net-Worm.Win32.Doomjuice - Ikarus Virus Scanner	
Assinatura MD5: 8f9427ae6938509aeb3366188289afa5 Categoria: Net-Worm / Plataforma afetada: todos os Windows com plataforma 32bits Propagação: este tipo de <i>worm</i> pode ser difundido através de recursos de rede por meio de vulnerabilidades de segurança no sistema operacional ou aplicativos. Também podem ser propagados em conjunto com outros tipos de <i>malware</i>. Ações: este <i>malware</i> ataca computadores que foram infectados pelos worms <i>Mydoom.A</i> e <i>Mydoom.B</i>, sua funcionalidade é pesquisar computadores que estão com a porta 3127/TCP aberta, caracterizada como <i>backdoor</i> usado pelo <i>Mydoom.A</i> e <i>Mydoom.B</i> para poder lançar um ataque de Negação de Serviço (<i>DoS</i>) contra o site www.microsoft.com Impactos: Ameaça à privacidade: moderado Ameaça à produtividade: moderado Ameaça à integridade do sistema: moderado Risco geral: moderado	
Análise de Risco – (Anubis,2010)	
• Capacidade de alta execução - Este <i>malware</i> registra processos para serem executados automaticamente no sistema de inicialização: risco médio • Alterar configuração de segurança do Internet Explorer – Esta alteração pode afetar diretamente a navegação na internet: risco médio • Cria arquivos no diretório de sistema do Windows – o <i>malware</i> pode fazer uma cópia de si mesmo no diretório de sistema do Windows para manter-se oculto para o usuário: risco médio • Executa varredura de rede – Este <i>malware</i> executa varredura nos endereços IP da rede em busca de potenciais alvos vulneráveis: risco alto • Executa modificação e destruição de arquivos - O executável modifica e destrói arquivos; esta ação não pode ser desfeita: risco alto • Executa atividades no registro do Windows – O executável lê e altera valores de registro, bem como a criação de registro de chaves: risco baixo	

Quadro 10 – Dados sobre o primeiro *malware* coletado

3.4. *Malware* mais coletados

No total foram coletadas 2.327 assinaturas. Dentre elas, 2.261 tinham o mesmo *hash md5* e 48 com diferentes *hash*. Todos eles foram encaminhados para análise no *Sandbox Anubis*. O catálogo realizado a partir da sessão anterior e apresentado no Apêndice B permitiu levantar o volume de ataque dos 5 *malware* mais comuns capturados pelos *Honeypots*, e dentre eles se destacaram:

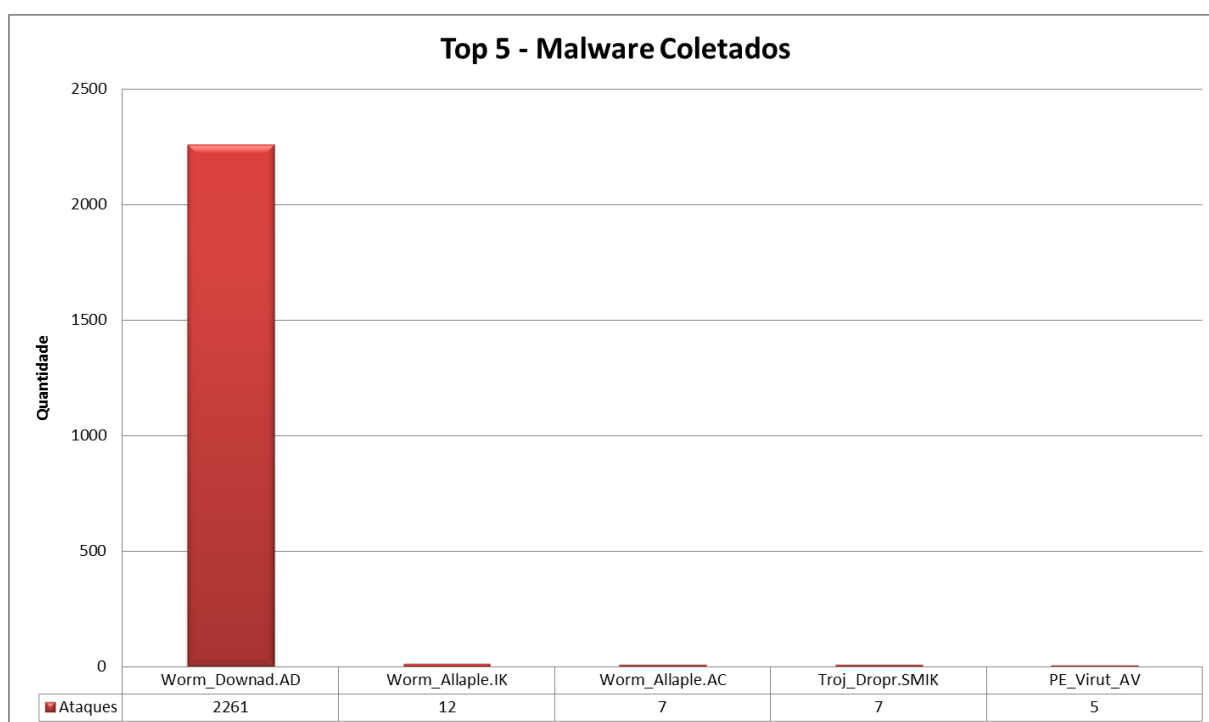


Figura 2-3 – Top 5 dos *malware* coletados pelos *honeypots*
(Elaborada pelo autor)

Nesta mesma sequência são apresentados os detalhamentos das características principais de cada um:

- a) **Worm_Downad.AD:** *malware* do tipo *worm*, ele se propaga via rede através da vulnerabilidade relatada pelo boletim Microsoft MS08-067, bem como através de dispositivos removíveis e compartilhamento de redes, conforme a biblioteca de ameaças da TrendMicro (2011). Ele foi descoberto em dezembro de 2008, possui uma classificação de risco baixa, mas um potencial de dano e distribuição médio (TRENDMICRO, 2011).

- b) **Worm_Allaple.IK:** *malware* do tipo *worm*, ele se propaga via rede através da vulnerabilidades relatadas pelo boletim Microsoft MS04-011, MS03-026, MS05-039 e MS06-040, e também através de compartilhamentos de rede, conforme a biblioteca de ameaças da TrendMicro (2011). Foi descoberto em fevereiro de 2007, tem a capacidade de infectar arquivos HTML e proporcionar ataques do tipo *DDoS* em *sites* específicos codificados em seu código fonte. Sua classificação de risco é baixa, mas seu potencial de dano e distribuição são caracterizados como alto (TRENDMICRO, 2011).
- c) **Worm_Allaple.AC:** *malware* do tipo *worm*, é uma variação atualizada do Worm_Allaple.IK, conforme a biblioteca de ameaças da TrendMicro (2011). Ele foi descoberto em março de 2009, tem a capacidade de proporcionar ataques do tipo *DDoS* em *sites* específicos codificados em seu código fonte, além de executar rotinas de *backdoor*, nas quais abre portas TCP randomicamente para diversos endereços remotos, com o intuito de permitir acesso remoto a um atacante mal intencionado. Sua classificação de risco geral é baixa, mas seu potencial de dano e distribuição é caracterizado como alto (TRENDMICRO, 2011).
- d) **Troj_Dropr.Smik:** *malware* do tipo *trojan*, seu código malicioso foi capturado nos primeiros dias de sua propagação através da Internet (TRENDMICRO, 2011). Ele se propaga via rede através da vulnerabilidade relatada pelo boletim Microsoft MS08-067. Foi descoberto exatamente na data de sua coleta, 25 de janeiro de 2011, e seu ataque foi originado na Colômbia (ANUBIS, 2011). Segundo a TrendMicro (2011), sua classificação de risco, potencial de dano e distribuição são caracterizados como baixo, o que difere da análise gerada pelo Anubis (2011), que relata um alto grau de risco em relação ao uso de memória, alteração e danos irreversíveis nos arquivos do sistema operacional e risco médio para produzir processos durante sua execução.
- e) **Pe_Virut_Av:** *malware* do tipo *vírus*, se propaga via rede através da vulnerabilidade relatada pelo boletim Microsoft MS08-067. Este *malware* altera os registros do sistema operacional para executar um *bypass* no *firewall*. Sua principal característica é a conexão a um servidor *Internet Relay Chat* (IRC) para permitir que um invasor possa fazer *download* e a execução de arquivos (SOPHOS, 2011). Descoberto em dezembro

de 2009, possui uma classificação de risco baixa e potencial de dano baixo, mas potencial de distribuição médio (TRENDMICRO, 2011).

Uma observação importante relacionada ao *hash 9a8657a61daefd7053017103ab53cd6*: esse código malicioso foi coletado pelo *Dionaea* 2.261 vezes durante os 15 dias que o *framework* ficou em funcionamento, ou seja, 97,92% do montante total de arquivos binários coletados pelo *framework*, e apesar de ter seu primeiro relatório formado pelo *Sandbox Anubis* em 21.12.2010, ainda tem seu nome comum dado como desconhecido no Anúbis (2011), e também na base do Virustotal (2011). Só foi possível concluir a avaliação deste binário através da máquina virtual e escaneamento do arquivo pelo antivírus da empresa TrendMicro, que o identificou como WORM_DOWNAD.AD.

Troj_Dropr.Smik – TrendMicro / Trojan.Win32.Pincav - Ikarus Virus Scanner	
Assinatura MD5: f9b35b4f68ca6db76102bcd701999788 Categoria: Trojan / Plataforma afetada: Windows 2000, XP e Windows Server 2003 Propagação: este tipo de <i>worm</i> pode ser difundido através de recursos de rede por meio de vulnerabilidades de segurança no sistema operacional ou aplicativos. Ações: este <i>malware</i> ataca computadores que possuem a vulnerabilidade MS08-067 divulgada como crítica no Microsoft Security Bulletin através da porta 445/TCP, permitindo a execução de códigos remotos no sistema operacional. Impactos: Ameaça à privacidade: baixo Ameaça à produtividade: baixo Ameaça à integridade do sistema: baixo Risco geral: baixo	
Análise de Risco – (Anubis,2011)	
• Gravar áreas de memória externa - Este código malicioso mexe com a execução de outros processos: risco alto • Executa modificação e destruição de arquivos - O executável modifica e destrói arquivos; esta ação não pode ser desfeita: risco alto • Capacidade de alta execução - Este <i>malware</i> registra processos para serem executados automaticamente no sistema de inicialização: risco médio • Geração de processos – este <i>malware</i> gera processos em memória durante sua execução: risco médio • Corrompimento do malware – em sua execução, o <i>malware</i> não finaliza corretamente causando corrompimento de seu executável: risco médio • Executa atividades no registro do Windows – O executável lê e altera valores de registro, bem como a criação de registro de chaves: risco baixo	

Quadro 11 – Dados sobre o “malware Zero Day” coletado

3.5. Origem dos incidentes

O gráfico a seguir exibe uma classificação do percentual de participação dos países de onde se originaram as atividades maliciosas nos *Honeypots*. Essas estatísticas foram extraídas através dos números de conexões aceitas pelos *frameworks*.

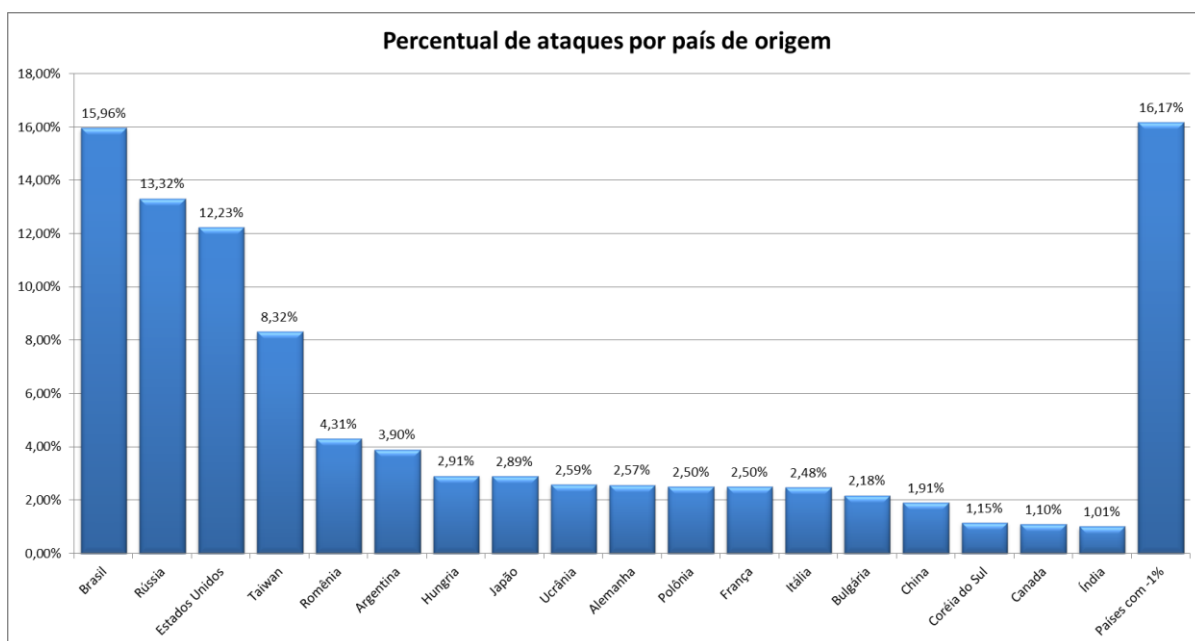


Figura 3-3 – Classificação dos países de origem dos ataques
(Elaborada pelo autor)

No primeiro lugar dessa classificação encontra-se o Brasil, um fator preocupante, pois devemos lembrar que estamos falando sobre *malware*, que em sua grande maioria é propagado pela internet através de outros computadores infectados.

Essa estatística fornece a visão de um problema sério nos computadores conectados na Internet brasileira, apesar do tempo de pesquisa ser sido baixo, é um indicativo para um número alto de computadores infectados por códigos maliciosos, o que afeta não só a produtividade do equipamento bem como a geração tráfego desnecessário na Internet.

É preciso conscientizar as pessoas que utilizam a internet sobre o uso de ferramentas apropriadas, como antivírus, *firewall* ou os aplicativos comerciais conhecidos como *Internet Security*, pois vale o investimento para a proteção da informação.

3.6.IP de Origem versus Requisições de acesso

Nesta outra análise foi verificada a quantidade de acessos individualmente dos 10 endereços IP que mais fizeram requisições aos *Honeypots*, indicando o seu país de origem, as portas e o percentual das amostras relativas aos 10 endereços de rede. Dessas requisições de acesso foram relacionadas tanto as conexões aceitas como as conexões rejeitadas que apareceram nos *logs* do sistema.

Tabela 2 – Os 10 endereços IP que mais fizeram requisição no *Honeypot Nepenthes*

IP	Portas	País	%
125.230.159.221	8080,3128,1080/TCP	Taiwan	22,85
61.54.227.135	80/TCP	China	20,63
125.230.145.195	8080,3128,1080/TCP	Taiwan	10,57
178.162.174.195	8080,3128,8000/TCP	Alemanha	8,62
125.230.148.209	8088,6588,80/TCP	Taiwan	8,22
89.145.193.103	8080,3128,1080/TCP	Reino Unido	6,27
125.230.152.233	4107/TCP	Taiwan	5,87
85.185.173.28	8080,3128,1080,80/TCP	Irã	5,87
109.230.220.217	4879/TCP	Alemanha	5,61
178.162.248.58	8080/8000/8888	Alemanha	5,48

Fonte: amostragem referente a 776 acessos

Tabela 3 – Os 10 endereços IP que mais fizeram requisição no *Honeypot Dionaea*

IP	Portas	País	%
200.198.124.82	1433/TCP	Brasil	16,36
216.105.65.107	80,139,445/TCP	Estados Unidos	15,36
12.4.149.73	139,445,9988/TCP	Estados Unidos	12,43
82.246.72.215	139,445,9988/TCP	França	11,63
88.225.168.230	139,445,9988/TCP	Turquia	10,83
69.46.212.31	139,445,9988/TCP	Estados Unidos	9,36
216.19.50.234	139,445,9988/TCP	Estados Unidos	9,14
69.57.102.107	139,445/TCP	Estados Unidos	7,04
96.10.154.15	80,139,445/TCP	Estados Unidos	4,10
111.5.18.254	1433/TCP	China	3,75

Fonte: amostragem referente a 5.735 acessos

A partir dos dados obtidos, dentre os 10 endereços IP que mais fizeram acesso ao servidor *Nepenthes*, 47,52% são endereços de rede de Taiwan, contra 57,44% de endereços IP dos Estados Unidos, concentrados no *Dionaea*. O único país de origem onde houve tentativas de acessos em comum entre os dois sensores foi a China. Também pode ser vista uma grande diferença referente às portas exploradas na comparação entre as tabelas. A maioria das portas

que foram exploradas no “Top 10” do *Dionaea* são portas que estão em escuta no sensor, enquanto no *Nepenthes* aparece apenas a porta 80/TCP.

3.7.Portas exploradas

Os próximos dados da tabela nesta sequência da análise indica o percentual sobre as 10 portas mais exploradas nos *Honeypots*, sendo elas com seu *status* em escuta ou não. Este perfil de análise só foi possível através da biblioteca *libpcap* e o recurso *log_in_vain* discriminados neste documento.

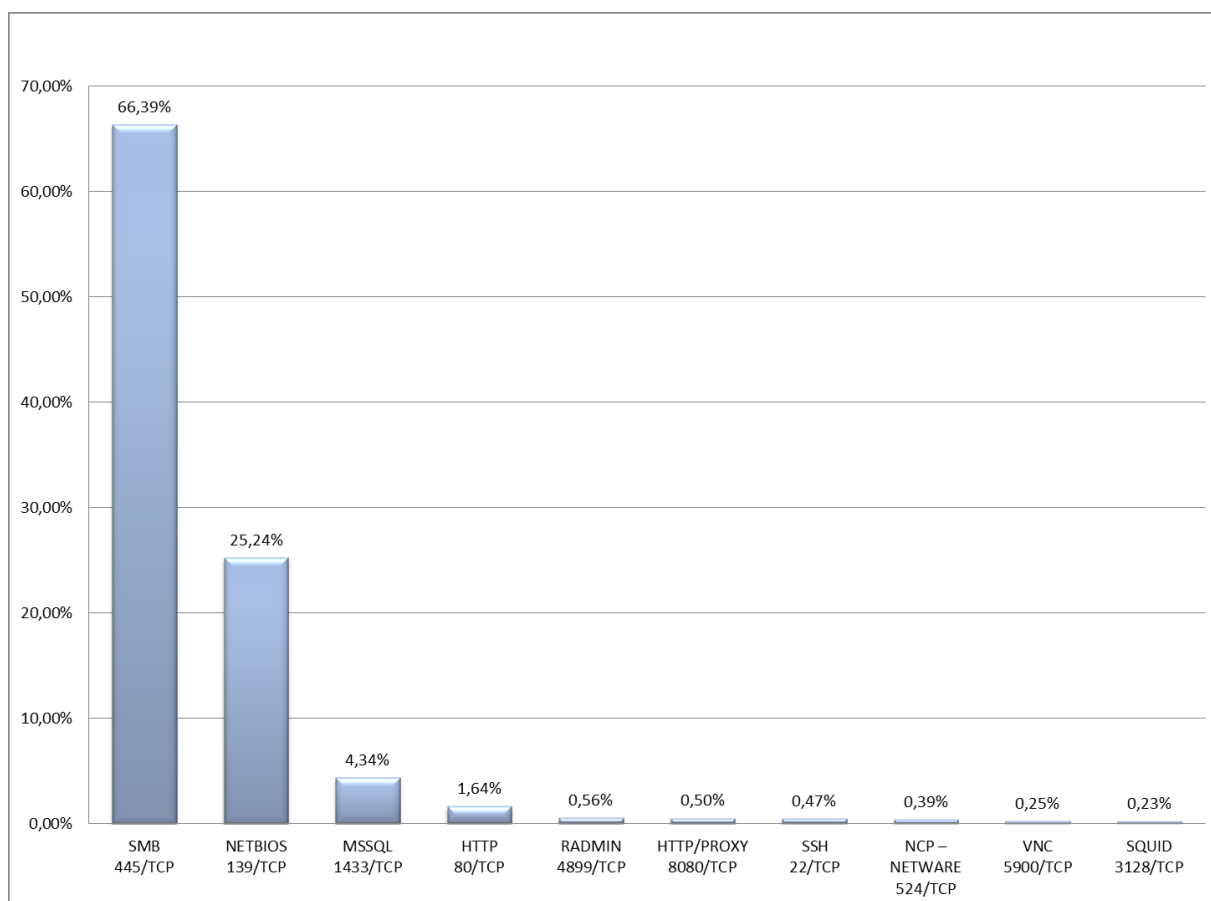


Figura 4-3 – Top 10 das portas exploradas (Elaborada pelo autor)

Nesta análise é possível confirmar o apetite da comunidade *underground* ao desenvolver e explorar ataques em relação à porta 445/TCP, pertencente ao protocolo *SMB*. Conforme as referências encontradas na CVE (2011), este protocolo possui o maior índice de vulnerabilidades encontradas e exploradas nas diversas versões do sistema operacional Windows, o número de ocorrências é grande porque o usuário em sua grande maioria não tem conhecimento dos serviços que estão em funcionamento em seu computador, ou não se

utilizam de ferramentas apropriadas que visam proteger o acesso às portas que estão em escuta, de acessos não autorizados advindos de uma rede externa.

3.8. Estudo geral dos ataques

Deu-se início ao monitoramento dos sensores exatamente às 9:32h do dia 12 de janeiro de 2011 e finalizado às 13:53h do dia 27 de janeiro de 2011, um período de quinze dias de coleta de *malware*. Este estudo compartilha informações relacionadas às datas de execução do sistema, volume de dados e *downtime* (tempo de parada do sistema). Para este estudo foram consideradas todas as conexões e tentativas efetuadas ao sistema.

Dionaea – Período vs. Volume de dados

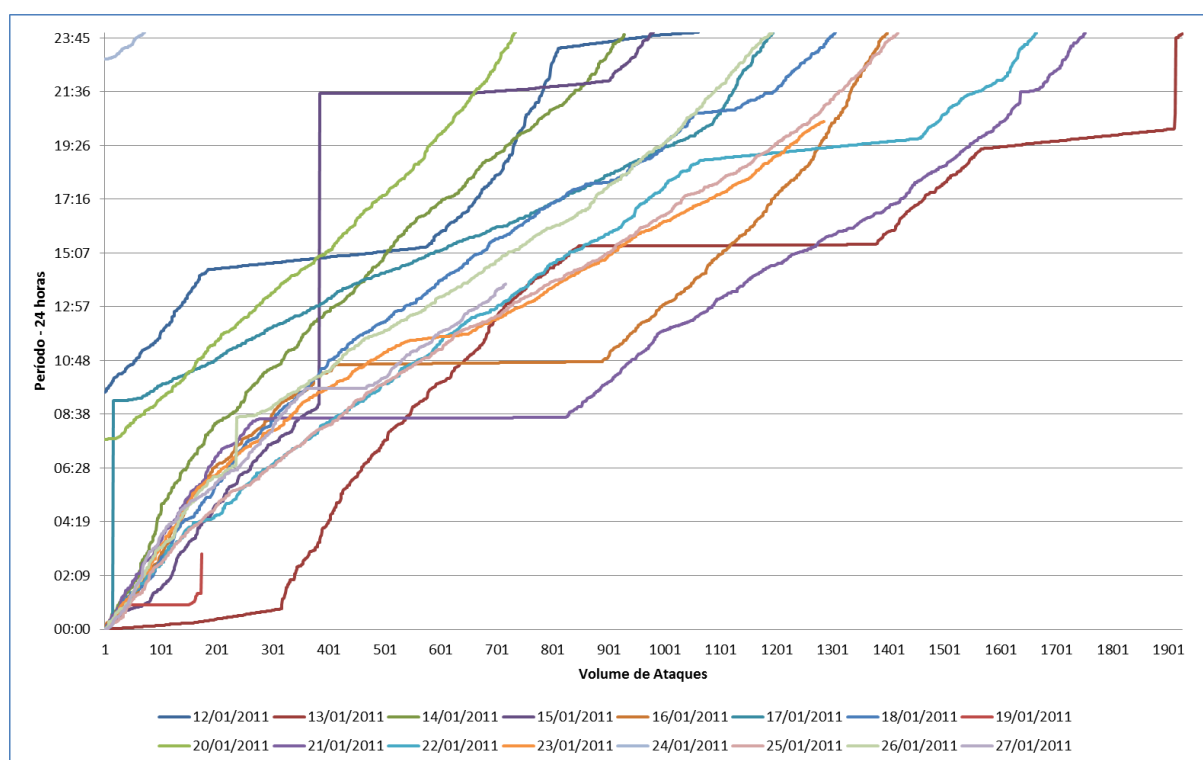


Figura 5-3 – Gráfico de linhas –*Dionaea* - Período vs. Volume de dados (Elaborada pelo autor)

A análise das figuras 5-3 e 6-3 ilustram:

Downtime, o tempo no qual o sistema ficou parado por um problema de *hardware* (travamento do equipamento devido utilização de peças antigas) ou por indisponibilidade do link de Internet. Do período total de 364 horas e 6 minutos, o *Honeypot Dionaea* ficou cerca de 68 horas fora do ar (18,89%), esse tempo pode ser visualizado graficamente na figura onde existe quebra da continuidade da linha ou o tracejo vertical exibido por um longo período.

Nos dias 13, 15, 16 e 21 aconteceram alguns momentos de maior concentração nos ataques (traços longos horizontais), nesta análise de dados foi encontrado um padrão de ataques, um volume por volta de 500 tentativas de conexão para cada dia em um curto período de tempo.

***Nepenthes* – Período vs. Volume de dados**

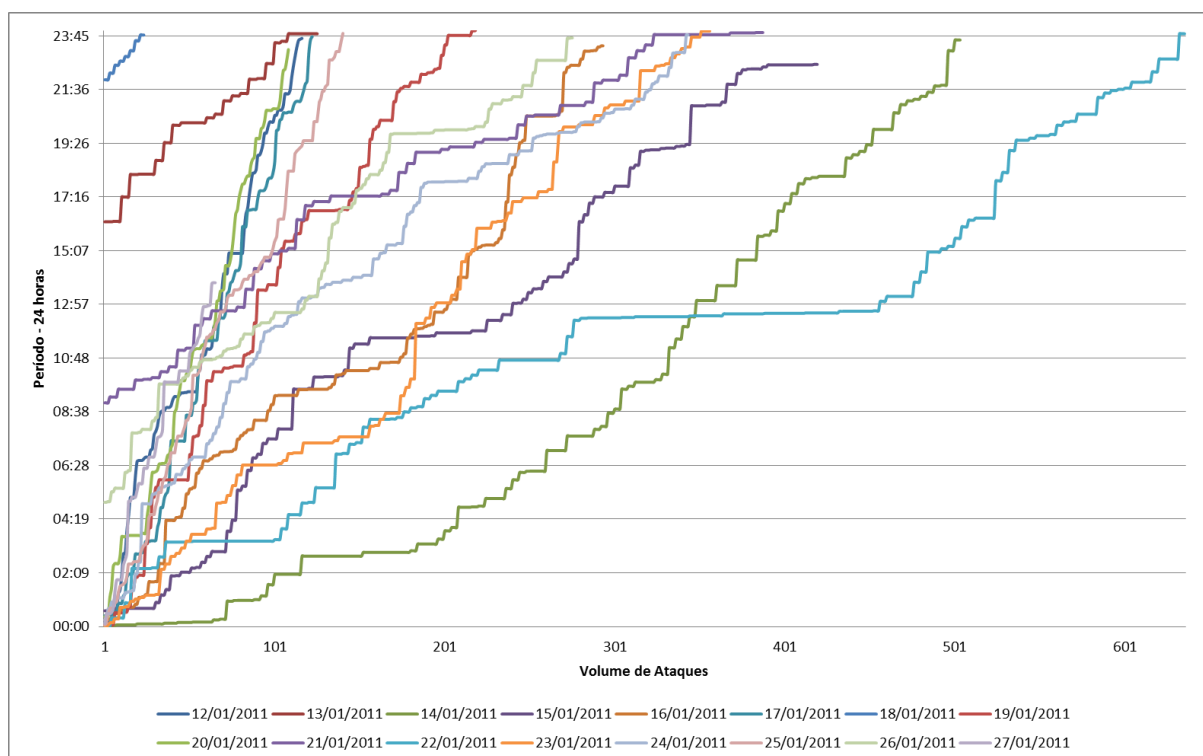


Figura 6-3 – Gráfico de linhas –*Nepenthes* - Período vs. Volume de dados (Elaborada pelo autor)

O *Downtime* relacionado ao *Honeypot Nepenthes* ficou em cerca de 33 horas (8,94%), um pouco menos da metade do tempo em que o *Dionaea* ficou *offline*, isto aconteceu porque o *Nepenthes* é mais fácil de administrar que o seu suposto sucessor. O *Dionaea* tem um nível de detalhamento maior, é gravado na base de dados *SQLite* e nos arquivos de *logs* do sistema, estas ações necessitaram de uma atenção especial para o espaço em disco do equipamento que efetuou alguns travamentos (devido à falta de espaço no *hard disk*) durante a sua execução.

Em ambos os gráficos é possível visualizar a exibição de um baixo volume de acessos muito próximos, exibidos entre o período das 00:00h às 08:30h, após este horário o volume de ataques aumenta gradativamente. A julgar que a maioria dos *malware* são propagados automaticamente através de equipamentos infectados e conectados pela rede, esta avaliação destaca que o maior tempo para propagação é o período em que as pessoas estão utilizando os

equipamentos, sem desconfiar que o mesmo pode ter sido “*escravizado*” por um programa de computador que está executando atividades maliciosas.

3.9. Estatísticas dos binários coletados – *Nepenthes* vs. *Dionaea*

Na sequência foram analisados os números para determinar/visualizar a quantidade de coletas realizadas por cada um dos sensores. As estatísticas geradas foram embasadas no volume diário de arquivos binários encontrados na pasta *../binaries* da estrutura dos *Honeypots*, local padrão onde foram armazenados os códigos maliciosos.

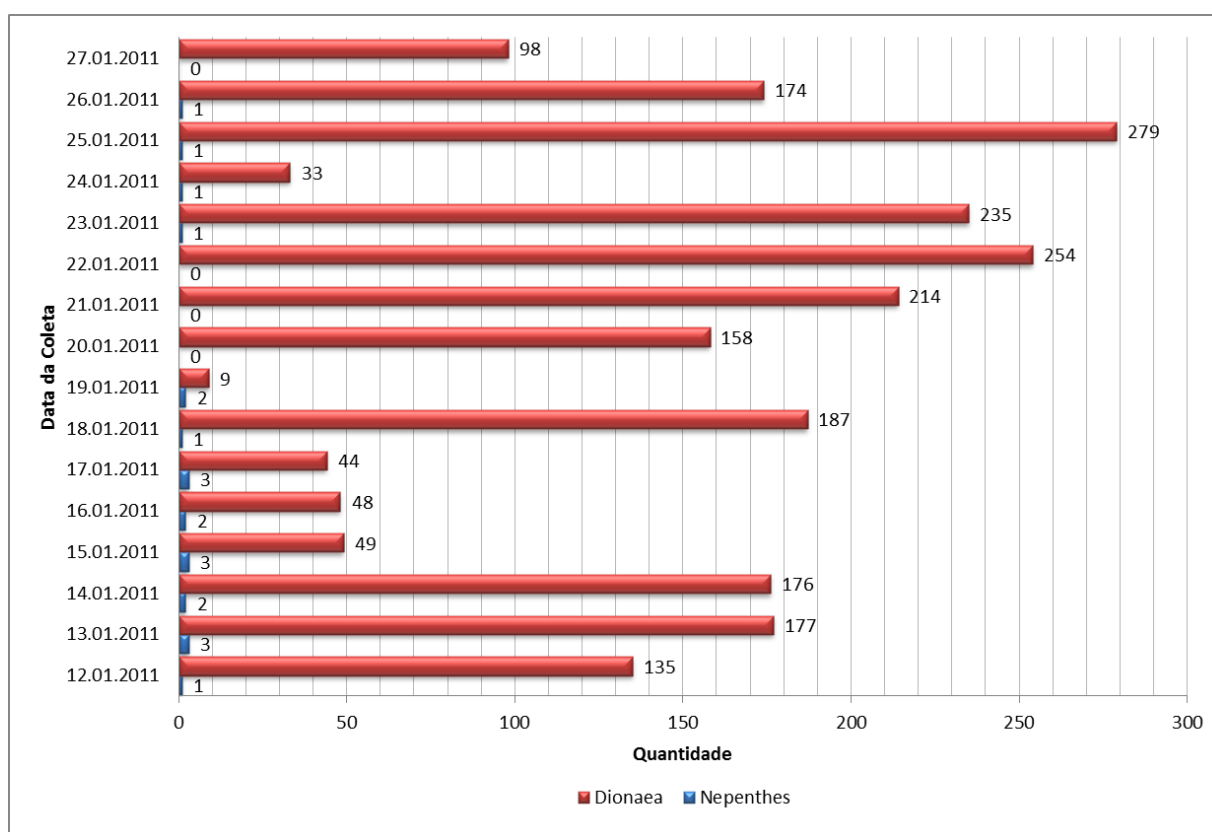


Figura 7-3 – Gráfico de barras ilustrando as estatísticas dos códigos binários coletados

De imediato é possível verificar que a quantidade de códigos maliciosos capturados pelo *Dionaea* é bem superior em relação ao *Nepenthes* (10.478% maior, esta estatística não deve ser confundida com a citada no item 2.6 por esta se tratar de informações diferentes). É possível afirmar que a essa diferença está na metodologia desenvolvida nos módulos de vulnerabilidade do *Dionaea*, utilizando a biblioteca *libemu* (explicada previamente no capítulo 2). Este módulo é o principal responsável pela comunicação efetiva dos *malware* e está claro que as emulações das vulnerabilidades dele são suficientemente eficazes para as capturas dos *malware*.

CONCLUSÃO

A conclusão final sobre a eficiência dos *Honeypots Nepenthes* e *Dionaea* foi dada sobre a visão na avaliação da análise dos dados resultantes dos ambientes experimentais apresentados nesta pesquisa, e principalmente embasado na quantidade e variedade de diferentes códigos maliciosos que o *framework Dionaea* coletou, o que indica que sua eficiência é superior a do *Nepenthes*. Mas porque o *Dionaea* foi melhor que o *Nepenthes* se as atribuições e atividades supostamente são as mesmas? Indica-se que a emulação relacionada ao protocolo SMB no *Dionaea* tem uma maior eficácia na capacidade de oferecer aos *malware* uma variedade maior de simulação das vulnerabilidades mais atuais dos sistemas operacionais baseados em sistemas “*Microsoft Windows*”, isso comprova que os desenvolvedores da aplicação estão no caminho certo dessa atualização tecnológica. Contudo, foi constatado um *bug* sério na aplicação. Esse *bug* remeteu à submissão do mesmo código malicioso diversas vezes com mesmo *hash md5* enviado e documentado pelo sistema, o que acabou gerando tráfego de rede e tarefas desnecessárias para o *Sandbox Anúbis*, que acabou emitindo vários *e-mails* referentes ao relatório do mesmo *malware*.

Em relação aos *malware* coletados, a avaliação foi executada através dos relatórios gerados pelo *Sandbox* e comparando cada uma de suas características principais através das bibliotecas de ameaças da TrendMicro (2011). A maioria foi considerada com alto grau de impacto, principalmente levando em consideração que o *malware* executa rotinas de *backdoor*, permitindo o acesso remoto ao equipamento infectado a um invasor mal-intencionado.

Quanto ao método de difusão usado pelos *malware*, especificamente a maioria aborda vulnerabilidades conhecidas nos sistemas operacionais ou se utilizam de canais abertos (serviços de rede em geral) para se auto propagar, como os vistos nesta pesquisa. Este tipo de falha pode ser mitigado facilmente, mantendo-se informado das vulnerabilidades através de boletins de segurança como os encontrados na CVE (2011), executando testes de vulnerabilidades no sistema operacional e corrigindo *bugs* através de atualizações e patches de segurança fornecidos pelo desenvolvedor e por fim utilizar-se de ferramentas apropriadas para proteção tais como firewall, antivírus, antispymware entre outros.

Apesar do último cenário proposto no ambiente experimental ter sido executado em um curto período de tempo, a coleta dos códigos maliciosos não foi tão baixo quanto esperada. Houve uma variedade interessante de *malware* (Apêndice B) e o sistema gerou um dos resultados mais gratificantes desta pesquisa: coletou a assinatura de um “*malware zero-day*” em seus primeiros dias de propagação na rede mundial de computadores. A experiência permitiu ser um dos primeiros a contribuir com uma amostra do *worm* conhecido como *Troj_Dropr.Smik* para análise no *Sandbox*, e ainda fazer uma das primeiras análises sobre seu impacto de risco, documentado nesta pesquisa.

As evidências são claras quanto à eficiência dada para cada ferramenta de *Honeypot* utilizada no ambiente experimental. O *Nepenthes*, com seu desenvolvimento parado, não consegue contribuir mais quando o fator é relacionado às novas tecnologias de difusão dos *malware*. O *Dionaea*, por sua vez, apesar de ser uma ferramenta nova na comunidade *open source*, precisa ser mais bem difundido. Ele precisa ser moldado pela experiência dos profissionais do ramo da segurança da informação para poder amadurecer. É uma experiência necessária para gerar maiores estatísticas, mais documentações sobre o uso da ferramenta e correção de possíveis *bugs* que o sistema possa ter.

De qualquer forma, as atualizações tecnológicas das ferramentas de *Honeypots* são de extrema importância, pois novas versões de *malware* são criadas todos os dias e seus métodos para difusão são aperfeiçoados a cada momento. Nesta pesquisa ficou evidente em todos os processos da implementação dos *Honeypots* que desde o início a instalação da ferramenta requer conhecimentos avançados de diversas áreas da computação, sejam elas relacionadas à infraestrutura, redes, sistemas operacionais e programação, o conhecimento e a pesquisa são imprescindíveis.

Concluindo, esta pesquisa permitiu o aprofundamento relacionado ao conhecimento das ferramentas utilizadas no “campo de batalha” da segurança da informação. Uma experiência única no âmbito computacional, que abriu uma nova visão referente à segurança imposta no espaço da Internet brasileira e à conscientização sobre o uso de ferramentas apropriadas para proteção, sejam elas em ambientes domésticos, sejam elas em ambientes corporativos, locais em que a preocupação torna-se uma só: proteger a informação a qualquer custo.

TRABALHOS FUTUROS

O ambiente experimental não cobriu todos os elementos disponíveis no *Honeypot Dionaea*, a pesquisa foi concentrada apenas no recurso de coleta de *malware*. Assim sugere-se como trabalhos futuros:

- **Maior foco no *Honeypot Dionaea*** – utilizando um novo laboratório experimental com maior tempo de coleta e monitoramento, para obter-se uma amostra maior e efetuar novos testes, abordando características e ferramentas que não foram exploradas nesta pesquisa.
- **Replicação remota da base SQLite** – desenvolvimento de um framework, para replicação remota automática e segura da base de dados utilizada para gravação dos *logs* de ações e interações executadas pelo *Honeypot Dionaea*.
- **Desenvolvimento de Interface Web para consulta de Logs** – a centralização da base de dados *SQLite* em um local remoto e seguro permitiria na sequência o desenvolvimento de aplicação baseada em linguagem Web para consulta dos *logs*, criação de relatórios customizados, geração de gráficos e tabelas facilitando a visualização e entendimento dos dados coletados.

REFERÊNCIAS

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR ISO/IEC 27001:** Tecnologia da informação – Técnicas de segurança – Sistemas de gestão da segurança da informação - Requisitos: elaboração. Rio de Janeiro, 2006.

ADDISON e WESLEY. **The Honeynet Project:** conheça seu inimigo. São Paulo: Pearson, 2002.

ANÚBIS. **Sandbox.**

Disponível em: <http://anubis.iseclab.org/>. Acesso em: 22 jan. 2011.

BAECHER, P. et alii. **The Nepenthes platform:** an efficient approach to collect malware. In: RECENT ADVANCES IN INTRUSION DETECTION (RAID). [S.l.]: Springer, Verlag, 2006. p. 165-184.

CASTRO, M. **Estudo sobre ataques de negação de serviços em redes IPv4:** prevenção, detecção e mitigação. São Paulo, 2011.

CHESWICK, B. **An evening with berferd in which a cracker is lured, endured, and studied,** 1992.

CVE. **Common Vulnerabilities and Exposures.**

Disponível em: <http://cve.mitre.org/>. Acesso em: 20 nov. 2010.

DIONAEA. **Site do desenvolvedor.**

Disponível em: <http://dionaea.carnivore.it/>. Acesso em: 13 set. 2010.

FONTES, E. L. G. **Praticando a segurança da informação.** Rio de Janeiro: Brasport, 2008.

HONEYNET. Site The Honeynet Project.

Disponível em <http://www.honeynet.org/project>. Acesso em: 20 Set. 2010.

MARCELO, A. e PITANGA, M. **Honeypots:** a arte de iludir hackers. Rio de Janeiro: Brasport, 2003.

MARX, A. **50 million viruses and rising.** Disponível em:

www.h-online.com/security/news/item/50-million-viruses-and-rising-1178664.html. Acesso em: 2 fev. 2011.

MCAFEE. **Threat Encyclopedia.**

Disponível em: <http://www.mcafee.com/us/mcafee-labs/threat-intelligence.aspx>. Acesso em: 26 jan. 2011.

MAXMIND. **GeoIP Tool.**

Disponível em: www.maxmind.com/. Acesso em: 30 jan. 2011.

MELO, S.; DOMINGOS, C.; CORREIA, L. e MARUYAMA, T. **BS7799**: da tática à prática em servidores Linux. Rio de Janeiro: Alta Books, 2006.

NEPENTHES. **Site do desenvolvedor**.

Disponível em: <http://nepenthes.carnivore.it/>. Acesso em: 7 ago. 2010.

SOPHOS. **Threat Encyclopedia**.

Disponível em: <http://www.sophos.com/security/analyses/viruses-and-spyware/>. Acesso em: 26 jan. 2011.

TECHNET. **Microsoft Technet – Microsoft Security Bulletin**

Disponível em: <http://www.microsoft.com/technet/security/current.aspx>. Acesso em: 20 nov. 2010.

TECHNET. **Microsoft Technet – Defining Malware**.

Disponível em: <http://technet.microsoft.com/en-us/library/dd632948.aspx>. Acesso em: 10 fev. 2011.

THE SANS INSTITUTE. **As 20 vulnerabilidades de segurança mais críticas na internet**. 2002.

TRENDMICRO. **Threat Encyclopedia**.

Disponível em: <http://about-threats.trendmicro.com/>. Acesso em: 26 jan. 2011.

VIRUSTOTAL. **Sandbox**.

Disponível em: www.virustotal.com/. Acesso em: 28 jan. 2011.

GLOSSÁRIO

3G: Terceira geração da tecnologia móvel celular, que proporciona uma transmissão de dados mais veloz.

ADSL: Asymmetric Digital Subscriber Line, ou “*Linha Digital Assimétrica para Assinante*” é a tecnologia que permite a transferência digital de dados em alta velocidade por meio de linhas telefônicas comuns.

API: Application Program Interface, ou “Interface de Programa Aplicativo”, é um conjunto de regras, protocolos e ferramentas utilizadas para desenvolvimento de aplicações para sistemas operacionais.

Backdoors: Programas com finalidade de abrir uma porta de acesso ao computador permitindo o controle remoto do equipamento.

Backup: Cópia de segurança de arquivos.

Blackhat: Pessoa que tenta acessar sistemas sem autorização, usando técnicas próprias ou não, no intuito de ter acesso a determinado ambiente para proveito próprio ou de terceiros.

Buffer overflow: transbordamento de dados de entrada de uma aplicação durante o processamento interno do sistema ultrapassando sua capacidade de armazenamento.

Cable Modem: tecnologia que utiliza a rede de transmissão de TV por cabo para transmissão de dados pela Internet.

Chroot: Chamada de sistema utilizada em sistemas operacionais padrão Unix, para criar um diretório root falso e temporário para execução de processos, dando a impressão que está na raiz do sistema, mas está em um diretório restrito, este processo também é conhecido como “*Jail*”.

CPU: Central de processamento de dados unificada, dispositivo núcleo de processamento utilizado em computadores.

Daemon: Programa de computador que roda em segundo plano.

Download: Transferência de arquivos entre computadores por meio de uma rede.

Fingerprint: Processo de identificação do sistema operacional através de programas de computador.

Firewall: Sistema ou combinação de sistemas que protege a fronteira entre duas ou mais redes.

- Frameworks:** É uma aplicação que integra a funcionalidade comum de várias aplicações.
- FTP:** File Transfer Protocol, protocolo para transferência de arquivos, recurso muito utilizado na Internet.
- Hash:** Representação matemática única de um conjunto de dados.
- Hosts:** Qualquer equipamento conectado a uma rede.
- HTTP** HyperText Transfer Protocol, protocolo de comunicação utilizado para visualização de páginas na Internet.
- Hyper-V** Aplicação da empresa Microsoft para virtualização de sistemas operacionais.
- IDS:** Intrusion Detection System, aplicação que permite o monitoramento de pacotes de rede para identificar acessos não autorizados.
- IPS:** Intrusion Prevention System, aplicação que além de monitorar pacotes de rede para identificar acessos não autorizados permite também tomar uma ação contra o evento.
- IPv6:** Nova geração do Protocolo Internet.
- IRC:** Internet Relay Chat. Protocolo de comunicação utilizado em sistemas de bate-papo (chat).
- Jail:** Vide Chroot.
- Link:** vínculos, convenções. Nas páginas da Web, um vínculo (link) de hipertexto, um botão ou trecho destacado do texto que, ao ser selecionado, remete o leitor a outra página.
- Log:** Registro do histórico de atividades realizadas ou de eventos ocorridos em um determinado sistema ou processo.
- Mbps:** Megabits por Segundo, medida utilizada para mensurar a velocidade de um link de Internet
- MD5:** Algoritmo utilizado para geração de hash.
- NFS:** Network File System, protocolo para acesso à arquivos em uma rede.
- NIS:** Network Information Service, serviço de rede desenvolvido pela Sun Microsystems utilizado para distribuição de informações através de uma rede.
- Open Source:** Termo criado para definir aplicações com seu código fonte aberto, também conhecido como *software* livre.
- Plugins:** São aplicações criadas para ampliar o funcionamento de um programa.

- PORTS:** Esquema de instalação de aplicativos utilizados pelo sistema operacional FreeBSD.
- POSIX:** Portable Operating System Interface, termo padrão utilizado para sistemas operacionais baseados em Unix.
- Python:** Linguagem de programação que pode ser do tipo interpretada, interativa, orientada a objetos e extensiva.
- RPC:** Remote Procedure Call, processo de comunicação que permite que um programa de computador crie uma subrotina ou processo para ser executado remotamente.
- RTP:** Real Time Protocol, protocolo responsável organização dos pacotes de dados da tecnologia VoIP que propicia a transmissão em tempo real.
- Scripts:** Sequência de comandos computacionais executadas através de um arquivo único para executar uma determinada tarefa.
- Shell:** Interface entre o usuário e o sistema operacional, permite a interpretação de comandos do sistema.
- Shellcode:** Grupo de instruções que podem ser executadas enquanto outro programa está rodando.
- SIP:** Session Initiation Protocol, protocolo utilizado para sinalização de telefonia IP.
- Snort:** Vide IDS.
- Software:** Programa de computador.
- SQLite:** Biblioteca em linguagem C que implementa um banco de dados SQL embutido.
- SSA:** Sigla para identificar a cidade de Salvador
- Strings:** Sequência de caracteres ordenada.
- TCP:** Transmission Control Protocol, protocolo de comunicação de rede utilizado para comunicar um ou mais hosts.
- TDS:** Tabular Data Stream, protocolo usado para transferir dados entre o servidor de banco de dados e o cliente.
- TFTP:** Trivial File Transfer Protocol, protocolo utilizado usualmente para transferência de arquivos.
- TLS:** Transport Layer Security, protocolo que utiliza criptografia para segurança em serviços de Internet.

Tripwire: Programa que detecta alterações em um sistema operacional.

Trojans Horses: malware que se passa por um programa de computador útil, mas possui código malicioso embutido.

UDP: User Datagram Protocol, protocolo utilizado para conexão de serviços de rede não orientados para conexão, isto é, não garante a entrega do pacote enviado pela rede.

Underground: Expressão utilizada para caracterizar o ambiente cultural dos *blackhats*.

Vírus: Programa de computador que pode danificar arquivos em um sistema operacional.

VMWare: Aplicação da empresa VMware NISE para virtualização de sistemas operacionais.

VoIP: Voice over IP

Worms: Código malicioso autopropagável que pode ser distribuído automaticamente de um computador para outro por meio de conexões de rede local ou pela Internet.

APÊNDICE A

Bkp-Nepenthes.sh

Exemplo do Script utilizado para compactação diária dos arquivos e registros relacionados ao Honeypot Nepenthes.

```
#!/bin/sh
# Variáveis utilizadas pelo script
export PATH=$PATH:/usr/local/bin
DATA=`date "+%Y%m%d"`

# Acesso à pasta de backup
cd /usr/bkp

# Compacta e grava os arquivos binários e os dumps coletados e logs gerados pelo honeypot
echo LOG Nepenthes - Rotate
tar -cvzf nepenthes.$DATA.tar.gz /usr/local/var/
rm -rf /usr/local/var/binaries/*
rm -rf /usr/local/var/hexdumps/*

# Limpa os logs do sistema
echo 'LOG Resetado' > /usr/local/var/log/logged_downloads
echo 'LOG Resetado' > /usr/local/var/log/logged_submissions
echo 'LOG Resetado' > /usr/local/var/log/nepenthes.log

# Compacta o arquivo de log de sistema messages
echo LOG Conexões de Servicos Inexistentes - Messages
tar -cvzf messages.$DATA.tar.gz /var/log/messages

# Compacta e limpa o log no formato de saída pcap
echo LOG IPFW - PCAP
tar -cvzf ipfw-pcap.$DATA.tar.gz /var/log/ipfw/ipfw.pcap
echo 'LOG Resetado' > /var/log/ipfw/ipfw.pcap

# Compacta e limpa o log de conexões gerado pelo firewall
echo LOG IPFW
tar -cvzf ipfw.$DATA.tar.gz /var/log/ipfw/ipfw.log
echo 'LOG Resetado' > /var/log/ipfw/ipfw.log
echo ### Bkp dos Logs Efetuados com Sucesso ###
```

Bkp-Dionaea.sh

Exemplo do Script utilizado para compactação diária dos arquivos e registros relacionados ao Honeypot Dionaea.

```
#!/bin/bash
```

```
# Variáveis utilizadas pelo script
```

```
export PATH=$PATH:/usr/local/bin
```

```
DATA=`date "+%Y%m%d"`
```

```
# Acesso à pasta de backup
```

```
cd /usr/bkp
```

```
# Compacta e grava os arquivos binários e os dumps coletados e logs gerados pelo honeypot
```

```
echo LOG Dionaea - Rotate
```

```
tar -cvzf dionaea.$DATA.tar.gz /opt/dionaea/var/
```

```
rm -rf /opt/dionaea/var/dionaea/binaries/*
```

```
rm -rf /opt/dionaea/var/dionaea/bistreams/*
```

```
# Limpa os logs
```

```
echo 'LOG Resetado' > /opt/dionaea/var/log/dionaea.log
```

```
echo ### Bkp dos Logs Efetuados com Sucesso ###
```

APÊNDICE B

CATÁLOGO DE MALWARE - HONEYPOT NEPENTHES DE 12.01.2011 A 27.01.2011

Assinatura MD5	Nome Comum TrendMicro / Ikarus	PORTA PROTO	Tipo	Plataf.	Impacto			
					Privacidade	Produtividade	Integridade	Risco Geral
8298acd88a61cbc9faa326f481ae30e0	Worm_Allaple.AC	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
1f6ddac6bdb424b0c40796e71d7c8a9b	Worm_Allaple.AC	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
649582c3bcf2b9c50868229ce0bb771e	Worm_Allaple.AC	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
93d2848b3e559bd1beae62f571133735	Worm_Allaple.AC	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
d3a6195e606cf9d46015a13a0d790a9f	Worm_Allaple.IK	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
eca0645fa05cc0e0540d87b78b27feb1	Pe_Virut.AV	445/TCP	Vírus	Win32	Baixo	Baixo	Baixo	Baixo
3875b6257d4d21d51ec13247ee4c1cdb	Worm_Allaple.AC	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
34821e0d72a689dd12581c82ca008c63	Worm_Allaple.AC	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
d5229d61ce878feb1c09588d8eaadc84	Net-Worm.Win32.Allaple	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
b44fac088c06bd9f080039934634635b	Worm_Allaple.IK	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
a5e5c4bdf7651426c82df4ade657da	Worm_Allaple.IK	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
c1989130056c32fa305e3de57f6f40f1	Mal_Allaple	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
0bfca1b823478ba70492806ff2f0d348	Net-Worm.Win32.Allaple	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
6b71d49f84b741f160f3ab2cef410dee	Net-Worm.Win32.Allaple	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
f3f9f07a7aebe1d630ed2451802e5433	Net-Worm.Win32.Allaple	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto

CATÁLOGO DE MALWARE - HONEYPOT NEPENTHES DE 12.01.2011 A 27.01.2011

Assinatura MD5	Nome Comum TrendMicro / Ikarus	PORTA PROTO	Tipo	Plataf.	Impacto			
					Privacidade	Produtividade	Integridade	Risco Geral
0e0fcfa8cb47c0742a2deda2bde366e9	Net-Worm.Win32.Allapple	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
13782996ed2578a4a65a1d88cb47508a	Worm_Allapple.IK	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
ca4cc3a35bd203cc7e86f23b7250e134	Net-Worm.Win32.Allapple	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
93b6f1729df298d9ad43a05643a72408	Net-Worm.Win32.Allapple	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
3cc8c200544f8deedc2ec0a8c8705907	Pe_Virut.AV	445/TCP	Vírus	Win32	Baixo	Baixo	Baixo	Baixo
cb1c31dc54f3ec665580afdf1bf07a2b	Net-Worm.Win32.Allapple	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto

CATÁLOGO DE MALWARE - HONEYPOT DIONAEA DE 12.01.2011 A 27.01.2011

Assinatura MD5	Nome Comum TrendMicro / Ikarus	PORTA PROTO	Tipo	Plataf.	Impacto			
					Privacidade	Produtividade	Integridade	Risco Geral
9a8657a61daef7053017103ab53cd6	Worm_Downad.AC	445/TCP	Worm	Win32	Baixo	Médio	Médio	Baixo
649582c3bcf2b9c50868229ce0bb771e	Worm_Allaple.AC	445/TCP	Worm	Win32	Alto	Alto	Alto	Alto
16eb0869d69a56a0fec761a8880bd70a	Troj_Gen.R47C2A9	445/TCP	Trojan	Win32	Alto	Alto	Alto	Alto
524305279349c3e0ce187384fe87ca13	Troj_Gen.R4CC2AJ	445/TCP	Trojan	Win32	Baixo	Baixo	Baixo	Baixo
4984ba2c3a202242ed8800dab41dc174	Troj_Injector.RA	445/TCP	Worm	Win32	Baixo	Baixo	Baixo	Baixo
245f0cbb559145980680617b0e573539	Pe_Virut.AV	445/TCP	Vírus	Baixo	Baixo	Baixo	Baixo	Baixo
97da6b4b7ae5cf523bbeb5b7471184b4	Worm_Rimecud.HH	445/TCP	Worm	Win32	Baixo	Baixo	Baixo	Baixo
8523e4d71daa169f0256a2f5793efe6b	Bkdr_Sdbot.BAR	445/TCP	Trojan	Win32	Alto	Baixo	Alto	Alto
997dbc4c346a80a8319bcd761aeade65	Troj_Gen.R47C2LT	445/TCP	Trojan	Win32	Alto	Alto	Alto	Alto
331e286c7ddac8a39f96b582054325ca	Pe_Virut.AV	445/TCP	Vírus	Baixo	Baixo	Baixo	Baixo	Baixo
aca0d514aeaf06f63d08ad4cfd4ee42f	Pe_Virut.AV	445/TCP	Vírus	Baixo	Baixo	Baixo	Baixo	Baixo
f9b35b4f68ca6db76102bcd701999788	Troj_Dropr.SMIK	445/TCP	Trojan	Win32	Baixo	Alto	Alto	Alto
79028319e22c2d2ff50b16f659470606	Troj_Pincav.DQ	445/TCP	Trojan	Win32	Alto	Baixo	Alto	Alto
164d08372d6998c6db135e6512b63683	Troj_Lsadcom.MCL	445/TCP	Trojan	Win32	Baixo	Baixo	Baixo	Baixo
7867de13bf22a7f3e3559044053e33e7	Troj_Meredrop.II	445/TCP	Trojan	Win32	Baixo	Alto	Alto	Alto
1e3b3286ca1c97596b27af7aae0f5b5e	Worm_Rimecud.SMC	445/TCP	Worm	Win32	Baixo	Baixo	Baixo	Baixo

CATÁLOGO DE MALWARE - HONEYPOT DIONAEA DE 12.01.2011 A 27.01.2011

Assinatura MD5	Nome Comum TrendMicro / Ikarus	PORTA PROTO	Tipo	Plataf.	Impacto			
					Privacidade	Produtividade	Integridade	Risco Geral
d29ec2d4f3a77f6929c17e3d64ac7546	Troj_Pincav.DQ	445/TCP	Trojan	Win32	Alto	Baixo	Alto	Alto
0a3c854964818a6a7b2ad436817fb416	Troj_Dropr.SMIK	445/TCP	Trojan	Win32	Baixo	Alto	Alto	Alto
ecfbf321d3dea3ec732e7957b1bb7b1a	Troj_Lamewar.VTG	445/TCP	Trojan	Win32	Baixo	Baixo	Baixo	Baixo
99140759749e639f2971219e38e4b56d	Troj_Dropr.SMIK	445/TCP	Trojan	Win32	Baixo	Alto	Alto	Alto
6f9290fa221efd4b2ea019b6260b5086	Troj_Dropr.SMIK	445/TCP	Trojan	Win32	Baixo	Alto	Alto	Alto
f5c6bec4488997b92a7d93b4e0a380a9	Troj_Dropr.SMIK	445/TCP	Trojan	Win32	Baixo	Alto	Alto	Alto
f273d1283364625f986050bdf7dec8bb	Worm_Mydoom.SMB	445/TCP	Worm	Win32	Baixo	Baixo	Baixo	Baixo
e42f97abdb0c0aaf3d6863b7ebd40fe2	Troj_Dropr.SMIK	445/TCP	Trojan	Win32	Baixo	Alto	Alto	Alto
e42f97abdb0c0aaf3d6863b7ebd40fe2	Troj_Dropr.SMIK	445/TCP	Trojan	Win32	Baixo	Alto	Alto	Alto

ANEXO A

EXEMPLO DE RELATÓRIO GERADO PELO SANDBOX ANÚBIS

[illegible]

```
[#####]
  Analysis Report for 247a51c8a6ea90209fad9bc9208dd48e
    MD5: 247a51c8a6ea90209fad9bc9208dd48e
[#####]
```

Summary:

- Performs Address Scan:
The executable scans a range of IP Addresses. In most cases these scans identify more potential vulnerable targets.
- Performs File Modification and Destruction:
The executable modifies and destructs files which are not temporary.
- Performs Registry Activities:
The executable reads and modifies registry values. It also creates and monitors registry keys.

[=====]
Table of Contents
[=====]

- General information
- 247a51c8a6.exe
 - a) Registry Activities
 - b) File Activities
 - c) Network Activities

```
[#####]
1. General Information
[#####]
[=====]
Information about Anubis' invocation
[=====]
Time needed:      241 s
Report created:   10/05/10, 13:12:38 UTC
Termination reason: Timeout
Program version:  1.74.3195
```

```
[#####]
2. 247a51c8a6.exe
[#####]
[=====]
General information about this executable
```

```
Analysis Reason: Primary Analysis Subject
Filename:      247a51c8a6.exe
MD5:          247a51c8a6ea90209fad9bcb9208dd48e
SHA-1:        7173a804b5ad81f75878bd632d8da6d08c54fe90
File Size:    59904 Bytes
Command Line: "C:\247a51c8a6.exe"
Process-status
at analysis end: alive
Exit Code:    0
```

```
[=====]
Load-time Dlls
[=====]
Module Name: [ C:\WINDOWS\system32\ntdll.dll ],
Base Address: [0x7C900000 ], Size: [0x000AF000 ]
Module Name: [ C:\WINDOWS\system32\kernel32.dll ],
Base Address: [0x7C800000 ], Size: [0x000F6000 ]
```

```
[=====]
Run-time Dlls
[=====]
Module Name: [ C:\WINDOWS\system32\comctl32.dll ],
Base Address: [0x5D090000 ], Size: [0x0009A000 ]
Module Name: [ C:\WINDOWS\system32\hnetcfg.dll ],
Base Address: [0x662B0000 ], Size: [0x00058000 ]
Module Name: [ C:\WINDOWS\system32\rsaenh.dll ],
Base Address: [0x68000000 ], Size: [0x00036000 ]
Module Name: [ C:\WINDOWS\system32\mswsock.dll ],
Base Address: [0x71A50000 ], Size: [0x0003F000 ]
Module Name: [ C:\WINDOWS\System32\wshtcpip.dll ],
Base Address: [0x71A90000 ], Size: [0x00008000 ]
Module Name: [ C:\WINDOWS\system32\WS2HELP.dll ],
Base Address: [0x71AA0000 ], Size: [0x00008000 ]
Module Name: [ C:\WINDOWS\system32\ws2_32.dll ],
Base Address: [0x71AB0000 ], Size: [0x00017000 ]
Module Name: [ C:\WINDOWS\system32\icmp.dll ],
Base Address: [0x74290000 ], Size: [0x00004000 ]
Module Name: [ C:\WINDOWS\system32\imagehlp.dll ],
Base Address: [0x76C90000 ], Size: [0x00028000 ]
Module Name: [ C:\WINDOWS\system32\iphlpapi.dll ],
Base Address: [0x76D60000 ], Size: [0x00019000 ]
Module Name: [ C:\WINDOWS\WinSxS\x86_Microsoft.Windows.Common-
Controls_6595b64144ccf1df_6.0.2600.5512_x-ww_35d4ce83\comctl32.dll ],
Base Address: [0x773D0000 ], Size: [0x00103000 ]
Module Name: [ C:\WINDOWS\system32\ole32.dll ],
Base Address: [0x774E0000 ], Size: [0x0013D000 ]
Module Name: [ C:\WINDOWS\system32\MSVCRT.dll ],
Base Address: [0x77C10000 ], Size: [0x00058000 ]
Module Name: [ C:\WINDOWS\system32\advapi32.dll ],
Base Address: [0x77DD0000 ], Size: [0x0009B000 ]
Module Name: [ C:\WINDOWS\system32\RPCRT4.dll ],
Base Address: [0x77E70000 ], Size: [0x00092000 ]
Module Name: [ C:\WINDOWS\system32\GDI32.dll ],
Base Address: [0x77F10000 ], Size: [0x00049000 ]
Module Name: [ C:\WINDOWS\system32\SHLWAPI.dll ],
Base Address: [0x77F60000 ], Size: [0x00076000 ]
Module Name: [ C:\WINDOWS\system32\Secur32.dll ],
Base Address: [0x77FE0000 ], Size: [0x00011000 ]
Module Name: [ C:\WINDOWS\system32\shell32.dll ],
Base Address: [0x7C9C0000 ], Size: [0x00817000 ]
Module Name: [ C:\WINDOWS\system32\user32.dll ],
Base Address: [0x7E410000 ], Size: [0x00091000 ]
```

```
[=====]
SigBuster Output
[=====]
Allaple_Polymorphic_Packer vna SN: 1647

[=====]
Ikarus Virus Scanner
[=====]
Net-Worm.Win32.Allaple.e (Sig-Id: 196523)

[=====]
2.a) 247a51c8a6.exe - Registry Activities
[=====]
Registry Keys Created:
[=====]
Key: [ \CLSID\{E1494B43-0F8A-34F1-A956-C84AE6A8BDC7} ]
Key: [ \CLSID\{E1494B43-0F8A-34F1-A956-C84AE6A8BDC7}\LocalServer32 ]

[=====]
Registry Values Modified:
[=====]
Key: [ HKLM\SOFTWARE\CLASSES\CLSID\{E1494B43-0F8A-34F1-A956-C84AE6A8BDC7} ],
Value Name: [ ], New Value: [ rntl1wrqerhnhkjr ]
Key: [ HKLM\SOFTWARE\CLASSES\CLSID\{E1494B43-0F8A-34F1-A956-C84AE6A8BDC7}\LOCALSERVER32 ],
Value Name: [ ], New Value: [ C:\247a51c8a6.exe ]

[=====]
Registry Values Read:
[=====]
Key: [ HKLM\SOFTWARE\Microsoft\Cryptography\Defaults\Provider Types\Type
001 ],
Value Name: [ Name ], Value: [ Microsoft Strong Cryptographic
Provider ], 4 times
Key: [ HKLM\SOFTWARE\Microsoft\Cryptography\Defaults\Provider\Microsoft
Strong Cryptographic Provider ],
Value Name: [ Image Path ], Value: [ rsaenh.dll ], 4 times
Key: [ HKLM\SOFTWARE\Microsoft\Cryptography\Defaults\Provider\Microsoft
Strong Cryptographic Provider ],
Value Name: [ Type ], Value: [ 1 ], 1 time
Key: [ HKLM\SYSTEM\CurrentControlSet\Control\Session Manager ],
Value Name: [ CriticalSectionTimeout ], Value: [ 2592000 ], 1 time
Key: [ HKLM\SYSTEM\CurrentControlSet\Services\Winsock\Parameters ],
Value Name: [ Transports ], Value: [
0x5400630070006900700000004e0065007400420049004f00530000000000 ], 2 times
Key: [ HKLM\SYSTEM\Setup ],
```

Value Name: [SystemSetupInProgress], Value: [0], 1 time
 Key: [HKLM\Software\Microsoft\Cryptography],
 Value Name: [MachineGuid], Value: [4604e8cc-5b9c-4ffb-a374-a62e6d0494fc], 4 times
 Key: [HKLM\Software\Policies\Microsoft\Windows\Safer\CodeIdentifiers],
 Value Name: [TransparentEnabled], Value: [1], 1 time
 Key: [HKLM\System\CurrentControlSet\Control\Terminal Server],
 Value Name: [TSUserEnabled], Value: [0], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\Tcpip\Parameters\Winsock],
 Value Name: [HelperDllName], Value: [%SystemRoot%\System32\wshtcpip.dll], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\Tcpip\Parameters\Winsock],
 Value Name: [Mapping], Value: [0xb000000300000002000000010000000600000002000000010000000000], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\Tcpip\Parameters\Winsock],
 Value Name: [MaxSockaddrLength], Value: [16], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\Tcpip\Parameters\Winsock],
 Value Name: [MinSockaddrLength], Value: [16], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\Tcpip\Parameters\Winsock],
 Value Name: [UseDelayedAcceptance], Value: [0], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters],
 Value Name: [WinSock_Registry_Version], Value: [2.0], 2 times
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5],
 Value Name: [Num_Catalog_Entries], Value: [3], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5],
 Value Name: [Serial_Access_Num], Value: [4], 2 times
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000001],
 Value Name: [DisplayString], Value: [Tcpip], 4 times
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000001],
 Value Name: [Enabled], Value: [1], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000001],
 Value Name: [LibraryPath], Value: [%SystemRoot%\System32\mswsock.dll], 2 times
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000001],
 Value Name: [ProviderId], Value: [0x409d05229e7ecf11ae5a00aa00a7112b], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000001],
 Value Name: [StoresServiceClassInfo], Value: [0], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000001],

HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000002],
 Value Name: [DisplayString], Value: [NTDS], 4 times
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000002],
 Value Name: [Enabled], Value: [1], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000002],
 Value Name: [LibraryPath], Value: [%SystemRoot%\System32\winnr.dll], 2 times
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000002],
 Value Name: [ProviderId], Value: [0xee37263b80e5cf11a55500c04fd8d4ac], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000002],
 Value Name: [StoresServiceClassInfo], Value: [0], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000002],
 Value Name: [SupportedNameSpace], Value: [32], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000002],
 Value Name: [Version], Value: [0], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000003],
 Value Name: [DisplayString], Value: [Network Location Awareness (NLA) Namespace], 4 times
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000003],
 Value Name: [Enabled], Value: [1], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000003],
 Value Name: [LibraryPath], Value: [%SystemRoot%\System32\mswsock.dll], 2 times
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000003],
 Value Name: [ProviderId], Value: [0x3a244266a83ba64abaa52e0bd71fdd83], 1 time
 Key: [HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5\Catalog_Entries\000000000003],
 Value Name: [StoresServiceClassInfo], Value: [0], 1 time
 Key: [

```
[=====]
Monitored Registry Keys:
[=====]
Key: [
HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\NameSpace_Catalog5 ],
    Watch subtree: [ 0 ], Notify Filter: [ Key Change ], 1 time
Key: [
HKLM\System\CurrentControlSet\Services\WinSock2\Parameters\Protocol_Catalog9 ],
    Watch subtree: [ 0 ], Notify Filter: [ Key Change ], 1 time

[=====]
2.b) 247a51c8a6.exe - File Activities
[=====]
Files Read:
[=====]
File Name: [ C:\247a51c8a6.exe ]
File Name: [ C:\WINDOWS\system32\rsaenh.dll ]

[=====]
Files Modified:
[=====]
File Name: [ Ip ]
File Name: [ \Device\Afd\AsyncConnectHlp ]
File Name: [ \Device\Afd\Endpoint ]
File Name: [ \Device\Ip ]
File Name: [ \Device\Tcp ]

[=====]
Device Control Communication:
[=====]
File: [ \Device\KsecDD ], Control Code: [ 0x00390008 ], 8 times
File: [ \Device\Tcp ], Control Code: [ 0x00120003 ], 6 times
File: [ \Device\Ip ], Control Code: [ 0x00120000 ], 585 times
File: [ \Device\Afd\Endpoint ], Control Code: [ AFD_GET_INFO (0x0001207B) ], 2 times
File: [ \Device\Afd\Endpoint ], Control Code: [ AFD_SET_CONTEXT (0x00012047) ], 1664 times
File: [ \Device\Afd\Endpoint ], Control Code: [ AFD_SET_INFO (0x0001203B) ], 555 times
File: [ \Device\Afd\Endpoint ], Control Code: [ AFD_BIND (0x00012003) ], 554 times
File: [ \Device\Afd\Endpoint ], Control Code: [ AFD_GET_TDI_HANDLES (0x00012037) ], 1604 times
File: [ \Device\Afd\AsyncConnectHlp ], Control Code: [ AFD_CONNECT (0x00012007) ], 555 times
File: [ \Device\Afd\Endpoint ], Control Code: [ AFD_SELECT (0x00012024) ], 554 times
File: [ unnamed file ], Control Code: [ 0x00120000 ], 1 time
File: [ C:\Endpoint ], Control Code: [ AFD_GET_TDI_HANDLES (0x00012037) ], 5 times
File: [ C:\Endpoint ], Control Code: [ AFD_SET_CONTEXT (0x00012047) ], 3 times
```

```
[=====]
Memory Mapped Files:
[=====]
File Name: [ C:\WINDOWS\system32\wshtcpip.dll ]
File Name: [ C:\WINDOWS\WinSxS\x86_Microsoft.Windows.Common-Controls_6595b64144ccf1df_6.0.2600.5512_x-ww_35d4ce83\comctl32.dll ]
File Name: [ C:\WINDOWS\WindowsShell.Manifest ]
File Name: [ C:\WINDOWS\system32\WS2HELP.dll ]
File Name: [ C:\WINDOWS\system32\comctl32.dll ]
File Name: [ C:\WINDOWS\system32\crypt32.dll ]
File Name: [ C:\WINDOWS\system32\hnetcfg.dll ]
File Name: [ C:\WINDOWS\system32\icmp.dll ]
File Name: [ C:\WINDOWS\system32\iphlpapi.dll ]
File Name: [ C:\WINDOWS\system32\mswsock.dll ]
File Name: [ C:\WINDOWS\system32\rsaenh.dll ]
File Name: [ C:\WINDOWS\system32\shell32.dll ]
File Name: [ C:\WINDOWS\system32\ws2_32.dll ]

[=====]
2.c) 247a51c8a6.exe - Network Activities
[=====]
ICMP Traffic:
[=====]
Requests: [ 300 ], Replies: [ 292 ], Scanned Subnet: [ 212.184.0.0/16 ]

[=====]
TCP Scans:
[=====]

[#####]
International Secure Systems Lab
http://www.iseclab.org

Vienna University of Technology      Eurecom France      UC Santa Barbara
http://www.tuwien.ac.at             http://www.eurecom.fr  http://www.cs.ucsb.edu

Contact: anubis@iseclab.org
```

FOLHA DE REGISTRO DO DOCUMENTO			
1. CLASSIFICAÇÃO/TIPO TC	2. DATA 14 de fevereiro de 2011	3. DOCUMENTO N° DCTA/ITA/TC-005/2011	4. N° DE PÁGINAS 97
5. TÍTULO E SUBTÍTULO: Análise da Difusão de Malware em Honeypots de Baixa Interatividade - Nepenthes x Dionaea			
6. AUTOR(ES): Milton de Jesus Melo			
7. INSTITUIÇÃO(ÕES)/ÓRGÃO(S) INTERNO(S)/DIVISÃO(ÕES): Instituto Tecnológico de Aeronáutica – ITA			
8. PALAVRAS-CHAVE SUGERIDAS PELO AUTOR: Honeypots. Malware. Internet. Programas. Dionaea. Nepenthes			
9. PALAVRAS-CHAVE RESULTANTES DE INDEXAÇÃO: Redes de comunicação; Detecção de intrusão (computadores); Segurança de dados; Segurança da informação de computadores; Avaliação de desempenho de software; Computação			
10. APRESENTAÇÃO: X Nacional Internacional ITA, São José dos Campos. Programa de Especialização em Tecnologia da Informação na Área de Segurança da Informação. Orientador: Prof. Ruy Flavio de Oliveira. Apresentação em 19/03/2011. Publicada em 2011.			
11. RESUMO: Invasão a computadores pessoais, vandalismo, realização de atividades ilegais e diversão são alguns dos diversos motivos que levam uma pessoa a invadir, explorar e comprometer um sistema computacional conectado a uma rede. Nessa guerra, o uso de sistemas de <i>Honeypots</i> tem se mostrado eficiente na coleta, análise e identificação de diversas técnicas e tipos de detecção de invasão em sistemas computacionais e na difusão de <i>softwares</i> maliciosos. Este trabalho é o resultado de uma pesquisa que visa à avaliação de ferramentas que utilizam a tecnologia de <i>Honeypots</i> com o objetivo de implantar, coletar e analisar informações de dois diferentes sistemas, utilizando uma abordagem experimental em um ambiente real de gerenciamento de <i>Honeypots</i> de baixa interatividade. Foi testada e comparada a eficiência de <i>Honeypots</i> relacionada especificamente à coleta de <i>malware</i> , programas que têm por objetivo principal a execução de atividades maliciosas em redes computacionais conectadas diretamente à internet.			
12. GRAU DE SIGILO: (X) OSTENSIVO () RESERVADO () CONFIDENCIAL () SECRETO			



Instituto Tecnológico de Aeronáutica
Autorização para disponibilização e distribuição de Trabalho de Curso

TERMO DE AUTORIZAÇÃO – TRABALHO DE CURSO DE ESPECIALIZAÇÃO

Eu, Milton de Jesus Melo, Brasileiro, casado, Coordenador de T.I., residente e domiciliado na Rua Brás Cubas, 253, Jardim Vitória, Caieiras, CEP 07700-000, São Paulo, portador do documento de identidade número 26.560.689-5, emitido por SSP/SP, inscrito no Cadastro de Pessoas Físicas do Ministério da Fazenda sob o número 286.593.088-24, na qualidade de titular dos direitos morais e patrimoniais de autor que recaem sobre meu trabalho de conclusão do Curso de Especialização em Segurança da Informação apresentado ao Instituto Tecnológico de Aeronáutica, intitulado Análise da Difusão de Malware em Honeypots de Baixa Interatividade – Nepenthes x Dionaea.

Com base no disposto na Lei Federal nº 9.610 de 19 de fevereiro de 1998, autorizo o Instituto Tecnológico de Aeronáutica, a partir desta data, a reproduzi-lo para armazená-lo permanentemente no Instituto, colocá-lo ao alcance do público por meios eletrônicos, em particular mediante acesso on-line pela rede mundial de computadores, permitir a quem a ele tiver acesso que o reproduza, dele extraindo cópia, de acordo com critérios estabelecidos pelo Instituto, desde que não vise lucros, até que manifestação em sentido contrário, de minha parte, determine a cessação desta autorização.

_____, ____ de _____ de ____
(Local da assinatura)

(Assinatura)